

Contents

Volume 04 — Hash, PKI & Network Attacks (L31-L40)	2
L31: Cryptographic Hash Functions — Part I	2
Learning objectives	2
What this lecture teaches	3
Key terms	8
Exam-oriented recap	8
L32: Cryptographic Hash Functions — Part II	9
Learning objectives	9
What this lecture teaches	9
Key terms	14
Exam-oriented recap	15
L33: Digital Signature and Certificate	15
Learning objectives	16
What this lecture teaches	16
Key terms	21
Exam-oriented recap	21
L34: Applications — Part I	21
Learning objectives	22
What this lecture teaches	22
Key terms	27
Exam-oriented recap	27
L35: Applications — Part II	28
Learning objectives	28
What this lecture teaches	28
Key terms	33
Exam-oriented recap	33
L36: Steganography	35
Learning objectives	35
What this lecture teaches	35
Key terms	40
Exam-oriented recap	41
L37: Biometrics	41
Learning objectives	41
What this lecture teaches	42
Key terms	48
Exam-oriented recap	48
L38: Network Based Attacks — Part I	49
Learning objectives	49
What this lecture teaches	49

Key terms	54
Exam-oriented recap	56
L39: Network Based Attacks — Part II	56
Learning objectives	56
What this lecture teaches	56
Key terms	62
Exam-oriented recap	62
L40: DNS and Email Security	62
Learning objectives	63
What this lecture teaches	63
Key terms	67
Exam-oriented recap	68

Volume 04 — Hash, PKI & Network Attacks (L31-L40)

Course: NPTEL Ethical Hacking (106105217) · **Instructor:** Prof. Indranil Sengupta, IIT Kharagpur

Series: notes-2 (transcript-grounded) — Hash functions, digital signatures, steganography, biometrics, DNS/email security.

Study notes derived from YouTube/Digimat lecture captions. For authorized lab use and exam preparation only.

L31: Cryptographic Hash Functions — Part I

Transcript: [31-cryptographic-hash-functions-part-i.md](#)

Video: <https://www.youtube.com/watch?v=DVpo78P1sOY>

Week / theme: Week 7 — Hash, PKI, steganography, network attacks

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Now in this lecture, we shall be starting our discussion on so called Cryptographic hash functions.
- We shall be discussing some of these methods which are based on cryptographic techniques.
- Now in this lecture, we shall be starting our discussion on so called Cryptographic hash functions.
- So, broadly speaking, let us first try to see what is a hash function.
- Well, for those of you who are coming from Computer Science background, you must have studied this topic on hash function, in some courses like data structures and algorithms.

What this lecture teaches

Core concepts from the lecture

Just we mentioned earlier that in any Security Applications authentication plays a very big role and to implement authentication one of the most important functionalities that we require is something called hash functions or Cryptographic hash functions.

Now in this lecture, we shall be starting our discussion on so called Cryptographic hash functions.

We shall see what it is exactly.

So, in this lecture we shall first be talking about some of the desirable properties of a hash function and we shall see that there are broadly two types of hash functions we can use; one that uses a key which is called keyed hash function and another one which does not require a key which is the un-keyed hash function.

So, broadly speaking, let us first try to see what is a hash function.

Well, for those of you who are coming from Computer Science background, you must have studied this topic on hash function, in some courses like data structures and algorithms.

There hash functions are used in various search applications, searching data in a table and so on and so forth, ok.

But here let us see in the present context, how we visualize a hash function as?

Continued

Well we visualize a hash function as, as some kind of computational function that can determine a hash digest H from a given message M which means if you are given a message M , we apply a hash function, we get something called the hash value or hash and digest H .

Now the point is that, the size of this M is typically much larger than that of H ; which means we are converting a very large number into a very small hash digest.

Now, because of this kind of many-to-one mapping, this kind of function is also sometimes referred to as a one-way function.

Why one way functions?

Because, since we are mapping a larger set to a smaller set, it is always the possibility that multiple values of M can map into this same value of H .

This is a so called many-to-one mapping, right.

So, because of that, we cannot uniquely do the reverse mapping from M to H .

So, for this reason, we call this hash function as a one-way hash function, ok.

Continued

And hash functions with some particular desirable properties that are more suitable for cryptographic applications; they referred to as cryptographic hash functions, ok.

So, what I have said is pictorially depicted in this diagram.

We have an arbitrary message M ; this can be of any arbitrary length.

Well, sometimes we add some additional bits at the end to make it a multiple of some units.

To make it, let us say an L bit number the total.

Then we apply a hash function, we get a small hash value, which is typically have a fixed length.

It can be 128-bit; it can be 160-bit; it can be 512-bit.

The size is fixed, fine.

Continued

Now, I had mentioned one of the main or primary applications of hash functions is in the domain of authentication.

So, I am again repeating what exactly authentication is?

Well authentication is a process through which we are trying to uniquely identify the person who is sending the message; that means, the identity of the sender has to be confirmed through this process.

So, here as I had said, we make use of cryptographic hash functions.

Now why do we need authentication; because you see in the Internet scenario, we really cannot see the other end of a communication.

We are carrying out the communication supposedly with some other person who I think that person is, but I have no way to confirm that exactly that same person is at the other end.

So, this authentication plays a big role in that respect, ok.

So, there are many applications which actually required this kind of thing to be done.

Continued

Require one of the parties that are involved in the communication must confirm the identity of the other party with whom he or she is communicating, ok.

So, most of the security applications starting from password based authentication to many others.

They very heavily rely on authentication, ok.

We shall be discussing some of these methods which are based on cryptographic techniques.

Of course, here in this lecture, we shall not be talking about something like biometric authentication where do we give our fingerprint or iris, but there the physical presence of the person is required; but here we are talking of the Internet where some messages are being transmitted and we have to carry out authentication, ok.

So, we cannot carry out biometric authentication.

So, this I have already mentioned earlier also.

Broadly message authentication can be carried out using conventional encryption that we shall see that using either symmetric key or public encryption, we can carry out some authentication; or even without encryption we can do message authentication.

Continued

We shall see these schemes.

Here we shall be generating some kind of an authentication tag and we will be appending it to the message and then the other side, some kind of a verification can be carried out, ok.

And there is something called a message authentication code which is very general that also we can use; where generally as this equation shows, we apply some kind of a function F on a message M with the help of a secret key value K just like encryption, similar to that and you generate something called a message authentication code or MAC that is appended with the message, so with the help of which we can authenticate, ok.

Now broadly speaking, I said that these kind of hash functions can be either keyed or unkeyed.

There can be a secret key or there can be no secret key.

Based on that we can broadly classify hash functions into something called modification detection codes which are unkeyed, which do not rely on any key.

So, whenever the messages modified, that can be detected, ok.

So, here this kind of hash function is used to preserve the integrity of message; which means the receiving end can tell whether the message is intact or it was modified.

Continued

So, whenever the message is modified, this so called MDC which is also coming as part of the message, will get modified, ok.

And the other one is that uses a secret key.

As I just now said, with message authentication code here we can preserve integrity of the message as well as we can identify the sender who is sending the message.

So, it is the second one which can be used for authentication, but the first one, you could use more for the purpose of verifying the integrity of a message.

So, you see this application of both kinds of hash functions are there in real security scenarios, security applications, ok.

So, this is a pictorial depiction of an un-keyed hash function.

So, you see, here on the left side, I have a message M that I want to transmit to a receiver.

So, what I do; I first apply a hash function on this message M, I get a hash digest MDC, modification detection code and what I do?

Continued

I append this MDC along with the message and I transmit this whole thing over the internet to the other side.

So, receiver will receive that same thing, the message M along with the MDC appended to it.

So, what the receiver will do?

The receiver will take out this message, will apply that same hash function which is known to both the parties.

And here also some MDC will get generated.

So, that MDC and the MDC that was received, will be compared.

So, if the message was modified in transit so, immediately there will be a mismatch.

You will know that the message integrity has been lost.

Continued

So, this is one simple way in which you can check the integrity of a message.

Now, talking about keyed hash function, here we are talking about a MAC algorithm which generates a message authentication code, which also takes a secret key K.

I am assuming here in this diagram, that this secret key is shared by the sender and the receiver both sides.

So, just like encryption and decryption.

So, the sender will generate this MAC, sorry using this key and the message M and this MAC, MAC will be appended to the message.

This will be transmitted and in a very similar way at the receiver end this message will again be fed to the MAC algorithm with the same key value K.

So, again a MAC will be generated and you compare these two MACs.

Now the MAC is generated using this key value and the MAC just transmitted, if they are not matching then either your key is wrong or your message was modified.

Continued

So, you can identify the sender also, because if you are using the same key with the sender, that means, you know that the same secret key is also lying with that sender.

It must be that sender sending it.

So, this is keyed hash function.

Now talking about cryptographic hash function as I had said, they should have some desirable properties.

Let us very quickly look at, what these desirable properties are?

Well any hash function, because it maps a larger set to a smaller set, there will be occurrence of something called collision.

So, what is a collision?

Collision means because you are mapping a larger set to a smaller set, there will always be two distinct messages say x and x prime which will map to this same hash value; because your message can be 1000 bit, your hash can be a 100 bits, ok.

Continued

So, there will always be a minute to one mapping and there will be such collisions happening.

So, there must be two messages x and x prime such that their hash values will be the same.

This is what we mean by collision and such a pair of messages x and x bar are set to result in a collision with respect to a hash function H , ok.

Now talking about the properties, the first is called first preimage resistance; well what this property says?

It says that except for a few hash values y , it should be very difficult to find a message x such as $H(x) = y$; which means I have given you some hash value and I asked you find out a message for which the hash value will be equal to that, I have given you.

So, it is not easy to do that; well if it were easy then an intruder can fabricate a message, modify a message in such a way that the same hash value will result.

That is difficult to do.

This is what is referred to as the first property of first preimage resistance.

Continued

Then comes the second level, second preimage resistance what it says, here I have given a message; given a message x , it is difficult to find another message x prime for which the hash values will be the same.

Like I am sending a message, the intruder cannot fabricate another different message for which the hash value will be the same as my original message.

So, it is not easy to do that; that is another property.

And finally, of course, collision resistance; it should not be very easy to do.

It will be very difficult to find two messages whose hash values are same.

So, if all these properties hold, then you say that my hash value is good; I can use it for a real cryptographic security application, ok.

So, whatever we had said just to summarize these things, desirable properties of a hash function H ; the first thing of course, is this H should be applicable to a message of arbitrary size.

Of course, not arbitrary long size, there is of course, an upper limit; but that upper limit should be very large.

Key terms

Term	Meaning in this lecture
Collision	because you are mapping a larger set to a smaller set, there will always be two distinct messages say x and x prime which will map to this same hash value; because your message can be 1000 bit, your hash can be a 100 bits, ok.
Now talking about the properties, the first	first preimage resistance; well what this property says?

Exam-oriented recap

- Well, for those of you who are coming from Computer Science background, you must have studied this topic on hash function, in some courses like data structures and algorithms.
- Because, since we are mapping a larger set to a smaller set, it is always the possibility that multiple values of M can map into this same value of H .
- Require one of the parties that are involved in the communication must confirm the identity of the other party with whom he or she is communicating, ok.
- So, most of the security applications starting from password based authentication to many others.
- So, whenever the messages modified, that can be detected, ok.
- So, whenever the message is modified, this so called MDC which is also coming as part of the message, will get modified, ok.
- So, you see this application of both kinds of hash functions are there in real security scenarios, security applications, ok.
- It must be that sender sending it.

L32: Cryptographic Hash Functions – Part II

Transcript: [32-cryptographic-hash-functions-part-ii.md](#)

Video: <https://www.youtube.com/watch?v=wRqJ9uvkR2s>

Week / theme: Week 7 — Hash, PKI, steganography, network attacks

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Now, we continue with our discussion on Cryptographic hash functions.
- We shall be continuing with our discussion in this lecture, this is the part II of the lecture.
- So, in this lecture we shall be first talking about several ways this one-way hash functions can be used and specifically we shall be looking at two different hash functions: one is the SHA-512; other is HMAC.
- Here now we shall first look at different ways to implement it.
- So, we shall look at that and then even without encryption/decryption methods.

What this lecture teaches

Core concepts from the lecture

Now, we continue with our discussion on Cryptographic hash functions.

If you recall in the previous lecture we had basically talked about the basic properties and requirements of a hash function.

In particular the hash functions which will be required for security or cryptographic applications.

We shall be continuing with our discussion in this lecture, this is the part II of the lecture.

So, in this lecture we shall be first talking about several ways this one-way hash functions can be used and specifically we shall be looking at two different hash functions: one is the SHA-512; other is HMAC.

Well talking about one-way hash function, if you recall, we mentioned because a hash function maps a larger set into a smaller set, there is a many to one mapping.

You cannot have a unique reverse mapping from the hash value to the message.

That is why we call it a one-way hash function.

Continued

Now, in computer systems for example, when you store the passwords there also this kind of one-way hash functions are used.

So, when you create a password, the passwords are not stored in the computer, because if you store the password in plain text, well anyone who gets access to the system can steal the passwords.

Some kind of one-way hash function is done and the hash value is stored in some table.

So, whenever you are logging in you are typing the password, again that one, our hash function is applied on your password and then you compare against the table whether it is matching with any one of the hash values.

That is how it is used.

Well, talking about two one-way hash functions.

Here now we shall first look at different ways to implement it.

We said that we can use some encryption or decryption algorithms to implement a, implement authentication.

Continued

So, we shall look at that and then even without encryption/decryption methods.

So, we will be using some cryptographic techniques like symmetric-key or public-key encryption in addition to hash functions, but the point to note is that you should clearly understand that why you were looking at so many varieties and alternatives, because the bottom line is that we need a hash function which will be efficient to compute both in software and possibly also in hardware, if you think of a hardware implementation.

Now, this encryption and decryption which possibly can also be used for authentication is, they are much slower than hash value computation.

This is the first thing you should remember and the second thing which also we mentioned earlier public-key encryption is much slower than symmetric-key encryption.

So, public-key encryption is the slowest, then symmetric-key encryption, then hash function computation which is the fastest.

So, first in this diagram we try to explain how we can implement a one-way hash function using symmetric-key encryption?

Now here you have a message.

So, what we do; we have a hash function H here.

Continued

So, we apply a hash function right and we get a hash digest out here.

So, we have a hash function, we apply to a message, we get a hash value, but after that we use another step of encryption, we have an encryption step where you use a private key K and a private key or symmetric-key encryption algorithm to encrypt the hash value.

We are not encrypting the message.

We are encrypting this small hash value to generate an encrypted hash.

So, what we are transmitting along with the message is the encrypted hash.

So, the advantage is that any intruder who is getting hold of it, because it does not know the value of K ; so, the encrypted hash he or she cannot access or process.

At the receiving site something similar is done.

So, the message along with this encrypted hash is received.

Continued

So, with the message part again the hash function is applied, the hash digest is obtained and with the encrypted hash part we apply a decryption algorithm with this same key value K .

So, we get back the hash value and you compare whether these two are matching or not.

Well, if this two are matching, we get two things together; one is of course, now means, we can identify the sender, because only the secret key K was shared with the sender.

So, because we are able to verify, so, it must be the case that the same value of K was used.

So, the sender has been authenticated.

Now, in addition, another thing also we will, because we achieve here is that we also verify the integrity of the message that the message was not modified during transmission, because if there is a modification in the message, then this hash value would have changed and so, the comparison would have failed, ok.

So, two things were achieving together; authentication and as well as message integrity ok.

Similar thing we can do using public-key encryption, because we had said earlier that one drawback of symmetric encryption was that both the parties must be sharing the same key.

Continued

So, the key must be sent to the other party through some, means, that is an initial step.

So, one way hash function is very similar here.

In this case with the message you again apply the hash function, you get the hash digest.

Well, you again do encryption, but this time you use a public-key encryption technique like RSA where you use the private key of the sender to encrypt.

I use my private key to encrypt the hash value.

This will be the encrypted hash value which is appended to the message and is transmitted.

When you see sometimes when someone encrypts with the private key, well using public encryption which sometimes say that it is a signature process, because I am only having my private key, encrypting the private key with the private key can be done only by myself as if it is carrying my signature something similar to that.

At the receiving end something similar is happening.

Continued

Firstly, with the message part the same hash functions is applied and with the encrypted hash part a decryption algorithm is run with the public-key of the sender and again we do a comparison.

So, if there is a match again just like the previous one and using symmetric-key encryption, here also we can verify two things together.

Firstly, that it must be signed by the intended sender, because, otherwise I could not have decrypted it using the public-key and secondly, the message is also not modified.

There is no loss in integrity because of that I could get back the correct hash value here, ok.

These two methods look very fine, but the only downside is that I am having to use encryption and decryption algorithms at the two ends and as I said encryption and decryption are slower as compared to hash function computation.

These methods are good alright, but they are becoming a little slower.

There is another approach we are trying to use here, where we are trying to avoid encryption.

What you are saying is something like this, let us assume that we are having some kind of a secret value K like a key shared by the sender and receiver, but we are not using this value K for encryption and decryption.

Continued

What we are doing; we are appending this K with the message, let us say this is, this K.

The message is there with us.

I append that secret value with the message and for the whole thing I applied the hash function.

I apply this hash value or hash function on this whole thing message plus K.

So, what hash function I get that also carries a flavor of K with it.

So, unless I have the current value of K, I cannot generate that hash function.

So, I sent the message only the message not the K, but along with the hash function I compute here.

At the other side something similar happens.

Continued

The message is received, but the same value K was also present to the receiver.

The receiver again appends that value K with the message and applies the hash value and gets a hash function, then it compares.

See here also we are achieving both the things, but without carrying out any encryption, because the key value is shared by the two parties.

Both the sender and receiver know.

So, if the comparison gives a success, it means that the message must be coming from the intended sender and also if there was some modification, the message must be, the hash value would have changed.

So, here there would be no match, ok.

So, I can achieve both the things but here I am avoiding this step of encryption, ok.

So, let us now look at a case study.

Continued

I talked about the various hash families.

SHA is one such very popular hash family and SHA-512 is one of the strongest member in that family.

Now, very broadly speaking, so, you see I am not going into detail, ok.

Just to look at it what you are doing here, I have the message that I want to compute the hash value on.

The first thing is that the total bit string that I am trying to hash, must be a multiple of 1024 bits that is a restriction with SHA-512.

So, if it is not a multiple of 1012, then some additional pad bits are added.

What does the pad bit contains?

It contains first the length of the message at the end, L.

Continued

It contains the value of L.

How many bits in the original message was there and then the pad consists of a single 1 followed by all 0s.

You do it to make it the whole thing a multiple of 1024 fine.

Then this each of these 1024 bit chunks, they are called, it is a M1 M2 to MN.

There are capital N such data blocks or chunks.

Now, each of them undergo the SHA-512 algorithm and by virtue of this a 512 bit of data is generated.

But to see how it is done, the first is M1 generates a 512 bit data, but this, this hash value, this hash value is fed as input to the second stage that creates another 512, this proceeds and finally, we get a single 512 hash value, the final value whatever comes that is taken as the 512 bit hash.

So, you see this is a fairly complicated process and this function F, this itself is very complicated that is why it is not very easy to break this, this one-way hash function.

Continued

So, the compression function means this F function we talked about; this F function is the basic building block of SHA-512 and as you have seen in the previous diagram that function F takes a block of the message which is 1024 bits in size, ok, and inside that F there are 80 iterations going on not 1, not 2 but 80 iterations or 80 rounds for each 1024 blocks and inside they maintain a 512 bit buffer which is updated at every step of these 80 iterations.

I am not going into the details of these 80 iterations.

Details are available in a, any, you can say in any standard textbook or if you search in the internet you will also find and it uses a 64 bit value, derived from the message block and also use a round constant in each of these 80 rounds and these round constants are generated from the first 80 prime numbers.

You compute the cube root of each of them and the result of that cube root whatever is obtained, those are taken as a round constants.

So, you see the things are fairly complicated inside, ok.

So, just bird's eye view of the round function.

What is happening inside that function F.

So, I am not going into the details of the explanation.

Key terms

Term	Meaning in this lecture
So, if the comparison gives a success, it	that the message must be coming from the intended sender and also if there was some modification, the message must be, the hash value would have changed.

Term	Meaning in this lecture
So, the compression function	this F function we talked about; this F function is the basic building block of SHA-512 and as you have seen in the previous diagram that function F takes a block of the message which is 1024 bits in size, ok, and inside that F there are 80 iterations going on not 1, not 2 but 80 iterations or 80 rounds for each 1024 blocks and inside they maintain a 512 bit buffer which is updated at every step of these 80 iterations.
Now, this 2 to the power 128 minus 1	here this message length will be 128 bits.
Now, let us look at another kind of a hash function which	HMAC.

Exam-oriented recap

- In particular the hash functions which will be required for security or cryptographic applications.
- So, whenever you are logging in you are typing the password, again that one, our hash function is applied on your password and then you compare against the table whether it is matching with any one of the hash values.
- This is the first thing you should remember and the second thing which also we mentioned earlier public-key encryption is much slower than symmetric-key encryption.
- So, the advantage is that any intruder who is getting hold of it, because it does not know the value of K; so, the encrypted hash he or she cannot access or process.
- So, because we are able to verify, so, it must be the case that the same value of K was used.
- Similar thing we can do using public-key encryption, because we had said earlier that one drawback of symmetric encryption was that both the parties must be sharing the same key.
- So, the key must be sent to the other party through some, means, that is an initial step.
- Firstly, that it must be signed by the intended sender, because, otherwise I could not have decrypted it using the public-key and secondly, the message is also not modified.

L33: Digital Signature and Certificate

Transcript: [33-digital-signature-and-certificate.md](https://www.youtube.com/watch?v=_FFHjz8di0w)

Video: https://www.youtube.com/watch?v=_FFHjz8di0w

Week / theme: Week 7 — Hash, PKI, steganography, network attacks
Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this lecture, we shall be exploring yet another application of hash functions which is Digital Signatures and Certificates.
- Let us try to understand the process here, ok.
- Now, in this lecture we shall be looking at two things, digital signatures and digital certificates.
- Talking about digital signatures, let us try to understand what it is.
- Talking about types of digital signatures, let us look at the first one which is, which was saying signature with appendix.

What this lecture teaches

Core concepts from the lecture

In this lecture, we shall be exploring yet another application of hash functions which is Digital Signatures and Certificates.

Now, digital signature is something which you must have heard of, which is being used nowadays in many online transactions and you will see that underlying any scheme for digital signature, you need to use some kind of a hash function.

Let us try to understand the process here, ok.

Now, in this lecture we shall be looking at two things, digital signatures and digital certificates.

Well, digital certificate is nothing but some kind of a standardization.

Standardization, so that people across the world can use digital signatures to, I mean authenticate documents and themselves with each other, ok.

Talking about digital signatures, let us try to understand what it is.

Well, you know what is mean by pen signatures.

Continued

Say the letter we sign, because the signature of every person is unique that is the underlying assumption.

We assume that it is unforgivable.

That is so called handwritten signature.

Now, in digital signature you can say it is the digital equivalent of handwritten signature.

I have a message, now it is not in the form of a hard copy or printed thing.

It is in the form of a file.

There should be an equivalent digital process when someone, some individual can put a digital signature.

Digital signature will be something similar to hash digest.

Continued

Like, I have a message M , I am saying that I will be appending a signature S to it, something similar to hash digest, so that if the receiver or any other person can verify that it is indeed my signature, if I have signed it, ok.

Now, digital signature technology is based on private key technology, because of the nice property of public key algorithms like RSA you have seen.

So, if I sign with my private key, then anyone in the world can decode it using my public key that is the good thing.

So, for this signing, for generating the signature what we need is the person who is signing.

Suppose I am signing, I must be using my private key.

So, you recall every individual will be having a private key and a public key, ok.

So, for signature the person will be using the private key which is not available with anyone else.

And the point is that it is difficult to forge, because anyone else cannot generate the same thing, same signature, because the value of d is only lying with me, and it is not easy for anyone else to guess or break what the value of d was, ok.

Continued

So, this private key value d cannot be replicated by anyone else and any entity without knowing d cannot generate the same valid signature, ok.

So, signature forging is not possible.

You see even with the pen and paper signature someone can try to make a signature similar to my signature and forge, but in digital case it is simply not possible, ok.

For verifying the signature that as said, the signature was done using the private key of the person who is signing.

Verification can be done by using the public key of the person, ok.

This is the property of public key cryptography and this also allows non-repudiation.

Because of the strength of the public key algorithm, well I am assuming quantum computers are not there in the picture.

So, just without that public key algorithms are known to be very strong.

Continued

They cannot be broken, ok.

So, this non-repudiation property also comes in as an added benefit.

Someone who has signed cannot later deny that well that is not my signature, because it is not possible to make a duplicate signature or forge a signature using this scheme, using these methods, all right.

Talking about types of digital signatures, let us look at the first one which is, which was saying signature with appendix.

Well, what is done here?

Just you see here in the signature generation process.

We will start with the message M , first we compute a hash value.

We use a hash function.

Continued

So, in the first step you see here which is a small m equal to H of capital M .

We generate the hash value of the message and generate a hash digest, small m , then we sign on that hash value.

A signing transformation f_s , f_s is referred to as the signing transformation, is applied on this $H M$, $H M$ is a small m .

So, on this small m I do my signature using my private key.

So, it is like an encryption process using RSA, let us say.

Let us say I am using RSA.

I have my private key.

I am doing an encryption that is the signature I am generating, that is my signature, S .

Continued

So, I can communicate the message M along with the signature S that is my signature.

So, as I said the other side whoever is receiving the message can actually verify the signature and verify the authenticity.

So, how the verification can be carried out?

So, again from the message, the hash value, small m is come, computed and the signature S was received.

Now, there is another function f_v which is applied, which in public key context will be the decryption operation.

Now, S will be decrypted using the public key e .

So, as you know encryption, decryption is exactly reversible with respect to the private key and the public key.

So, if you do the decryption, you will be getting some value m prime and you expect m and m prime to be the same.

Continued

If they are the same, you say the signature has been made.

This has been verified.

If they do not match, you say that there is a mismatch in the signature, not verified, ok.

This is how this key works, ok.

There is another approach here, we are not generating a separate signature rather we are encrypting the whole message, but of course this is much more expensive.

Just simply, for digital signature this second message is not visible, no one uses.

Let us see what this method is?

This is signature with message recovery.

Continued

Here this signing transformation is applied on the entire message.

Earlier we had used a hash function.

Here we are not using the hash function, ok.

So, what you are doing?

For signature generation, we are effectively encrypting the whole message, you see the signature, this signing transformation f_s is applied on the message and the private key d .

So, whatever signature we are generating is actually the encrypted version of my whole message, but that was encrypted by the private key of the signature, signer.

So, for verification the reverse process is done, f_v is applied on this signature using the public key e .

So, you are expected to get back the message.

Continued

So, whatever you get M prime, you verify it.

You see here we are not exactly sending a message, rather we are trying to authenticate, ok.

So, after decryption if you see that it is like a normal text which means that you have been able to successfully decode it.

You need not exactly verify whether M prime is equal to M because if it looks like English text, that means, you have been successful in decoding.

But if you want to be doubled sure you can make a check if M equal to M prime, right. Then signature verified; otherwise not verified.

But as I have said the second method is more expensive, because it involves encryption of a larger message and as I said public key encryption/decryption are expensive. They are much slower.

Continued

So, if you are trying to encrypt a large chunk of data, it will be quite slow.

So, there are other ways of generating signature also, I am not going to detail of this.

There is something called deterministic or probabilistic signatures.

Deterministic signatures are what we have just now talked about.

Given a message every time I sign, my signature will be the same, because I am using the same algorithm.

I am using the same private key.

I am using the hash function, so whatever signature S I generate, will be the same.

That is what is meant by deterministic signature.

Continued

The same signature will be generated on every occasion you run the signing algorithm.

But probabilistic signature is something which adds another level of security, that every time there may not be a match.

With some probability you say, on different runs of the signing algorithm, different signatures can be generated even for the same message.

So, there are many ways in which you can use this probabilistic signature.

I am again not going into detail.

But this adds the level of security to subsystem where really some very high level of security is required.

There you can go for probabilistic signature, ok.

Now, some examples of digital signatures, many examples are there Rabin, Elgamal, Schnorr, DSA, then elliptic curve, many methods are there.

Key terms

Term	Meaning in this lecture
Total break	somehow the attacker gets hold of my private key and that is the ultimate, ok.
And existing, for existential forgery	the attacker can generate signature on certain messages, but those messages cannot be generated by the attacker.
If you say that you are able to break it, which	you are able to break RSA, right.
Known message attack	the attackers knows some message and the corresponding signature pairs with that it can analyze and try to find out that whether you can make some modifications and generate a valid signature or not.
Revoke certificate	it goes to means, another list which means, those are the certificates which have been compromised.

Exam-oriented recap

- Now, digital signature is something which you must have heard of, which is being used nowadays in many online transactions and you will see that underlying any scheme for digital signature, you need to use some kind of a hash function.
- Suppose I am signing, I must be using my private key.
- But probabilistic signature is something which adds another level of security, that every time there may not be a match.
- But this adds the level of security to subsystem where really some very high level of security is required.
- You can do encryption and decryption, but the advantage is that the overhead of implementations much less, both in terms of memory and also in terms of speed, right.
- Now, talking about attacks on this kind of signatures.
- Total break means somehow the attacker gets hold of my private key and that is the ultimate, ok.
- If the attacker gets the signing key, then you can do anything, modify the message, again generate the signature appended to it.

L34: Applications — Part I

Transcript: [34-applications-part-i.md](#)

Video: <https://www.youtube.com/watch?v=jScv-KV8qhM>

Week / theme: Week 7 — Hash, PKI, steganography, network attacks

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Now, in this lecture which will be the Part I of the Applications, we shall be talking about something called secure socket layer or SSL and we shall see how SSL works.
- Now, in this lecture which will be the Part I of the Applications, we shall be talking about something called secure socket layer or SSL and we shall see how SSL works.
- So, this SSL is one such protocol which provides you with an optional added layer of security with respect to whatever message you are sending and receiving over TCP/IP.
- Let us see this, secure socket layer, SSL.
- Now, SSL was initially proposed and used by Netscape which is today known as Mozilla.

What this lecture teaches

Core concepts from the lecture

We shall now be looking at some of these security Applications.

Say, earlier we had looked at some very specific techniques for carrying out some specific operations like how to do authentication, how to ensure message integrity, how to do encryption, but now we talk about some kind of end to end applications which are used pretty widely in the Internet.

Now, in this lecture which will be the Part I of the Applications, we shall be talking about something called secure socket layer or SSL and we shall see how SSL works.

Now, SSL is important from the point of view of securing an organization or any network, because if you ensure or if you can provide with the mechanism so that people use this protocol SSL for communication, for sending confidential messages, then automatically there will be some kind encryption process that will be going in and any intruder or a hacker if it tries to break into the machine and if it breaks in even if then confidential information or secure information will not be leaked away.

So, this SSL is one such protocol which provides you with an optional added layer of security with respect to whatever message you are sending and receiving over TCP/IP.

Let us see this, secure socket layer, SSL.

Now, SSL was initially proposed and used by Netscape which is today known as Mozilla.

That was the first instance where SSL was used.

Continued

Subsequently this has become very popular.

Now, many people use it for providing secure communication and secure transmission of data, ok.

Now, particularly this SSL was used with respect to three protocols HTTP, LDAP and POP3.

We shall talk about these, because these were some of the most commonly used network traffic that were generated by users, right.

And this SSL uses TCP, because it relies on TCP to provide reliable end to end service.

On top of it provides some additional functionality so that additional level of security is provided, ok.

So, SSL can be used, which runs on top of TCP/IP to develop any security application in general.

Now, talking about these three protocols, as I said these are the most commonly used protocols.

Continued

We generate maximum amount of traffic on the network.

First is HTTP - Hyper-Text Transport Protocol which generates the requests and responses for all web applications, ok.

So, here when you are looking at the Internet, browsing the Internet will be generating all the requests through this HTTP protocol, ok.

So, this is the protocol to communicate between a web browser and a web server.

It is a two-way communication.

And there is another very important component or typically generated this, called LDAP - Lightweight Directory Access Protocol.

This is used an email and other services where information about some users and entities are stored in some directories to access them.

You need LDAP messages to be send and received.

Continued

And finally, for accessing electronic mails, POP3 is one of the protocols.

POP is the short form for Post Office Protocol, version 3.

It is used for retrieving mails from a email server, right.

So, these are some examples.

There are other examples also which use SSL.

So, pictorially this is how things work.

So, you see here you have TCP/IP.

TCP/IP and the underlying physical layer is here that provides you with the basic network interface over which you can transmit messages and packets.

Continued

Now, SSL sits on top of it.

So, you can generically call them as network layer.

Technically speaking this is actually a combination of network and transport layers, right, but you can say generically these are the two layers which provide transport of data over a network.

That is why you can roughly call it a network layer and above that you can have various applications.

So, I am showing only these three.

There can be others also.

Now, these three I have shown, because they use SSL.

They are known to use SSL, but there can be some other applications which may be directly using TCP/IP, but you can also develop some other applications which may be using SSL.

Continued

So, SSL is a layer which sits on top of TCP and it is an optional layer.

All applications do not use TCP, do not use this layer SSL.

They can directly interact with TCP, if they want, fine.

Now, the basic objectives of this secure socket layer or SSL are several.

First is authentication; the client and server, two parties are communicating over a network.

They must authenticate each other.

So, I know who is the other party.

The other party also knows who I am.

Continued

Then, ensure data integrity.

So, it will also take care that.

Data is not modified in transit.

If there is a data modification, it will be immediately detected at the receiving end.

And data privacy also, if you want.

So, encryption/decryption is also can be carried out as part of SSL.

So, SSL also hides the data that is being communicated between the two parties.

And this data privacy or this encryption is carried out not only for the application data that the user is generating, but also for the protocol data, because SSL also send some control messages.

Continued

Those can also be encrypted so that an intruder does not know what kind of protocol is being used, what kind of encryption method has been used.

Nothing is being disclosed in that case, fine.

Talking about the SSL architecture, there are broadly two layers of protocols; one is called SSL record protocol and another layer, there are protocols required to establish the connection, ok.

Now, SSL record protocol, all encryption and authentication hash function etc.

those are handled by this layer.

They take care of data security and data integrity that is the responsibility of the SSL record protocol.

So, all the methods we had talked about earlier, they are handled by that particular layer.

And for establishing SSL connection that is the initial.

Continued

So, whenever initially a connection is being set up here, the connection is a little different as compared with a normal TCP connection.

For a TCP connection, see you recall, there was a three-way handshake through which a sender process and a receiver process can establish a connection between them.

But, for SSL such a connection is required of course, but in addition a number of other things are required, because here we are talking about data privacy.

We are talking about authentication.

We need hash functions.

We need encryption algorithms; we need decryption algorithms.

So, both the parties must agree on which algorithm to use for encryption, for hash and everything.

So, it is during this initial in SSL connection phase all these things are decided by the two parties.

Continued

So, there are actually three protocols under this.

SSL handshake protocol, SSL ChangeCipherSpec, as the name implies some ciphers or the algorithms for encryption you can change here.

You can specify which method to use and SSL alert, in case of some problems.

These are the three kinds of different kinds of messages that can be exchanged in this second part.

So, pictorially speaking the layers are created like this.

So, earlier I had shown SSL as a single layer above TCP.

What you see here is TCP which of course, is sitting above IP.

And right above TCP you have first the SSL record protocol which is responsible for all the encryption and other security provisions which are provided.

Continued

And on top of it you have this SSL handshake protocol, ChangeCipherSpec and alert protocols which generates messages which are required for establishing the connections.

And all of these are going through the record protocol so that they can all be encrypted and then send in addition you can have your applications.

Now, applications do not interact with these three, they interact directly with the record protocol, ok.

This is how the entire protocols track for SSL looks like.

So, SSL record protocol as I have talked about, it is mainly responsible for two things.

One is data encryption and other is data integrity, right.

And other higher level SSL protocol like alert, ChangeCipherSpec etc.

they can also be, they are also used to encapsulate data sent by those protocols.

Continued

So, either to provide data encryption and integrity for application data or for SSL higher level protocols to encapsulate them and send.

Basic functions are it takes a message to be sent, first thing.

Fragment the message into smaller chunks.

The chunks for SSL are defined as 16 kilobytes.

So, if the message is larger, it is broken up into 16 kilobyte, pieces and each of these are handled in certain way and encapsulate each of the headers and create a record, encrypt the record and forward it to TCP for delivery.

The encrypted data is sent to TCP as a message.

So, TCP does not know what it is.

It is actually the encrypted data which is coming to TCP as a message which TCP sending to the other side, but before that all these things are happening; breaking up a larger message into smaller 16 kilobytes chunks, encrypting them and so on and so forth.

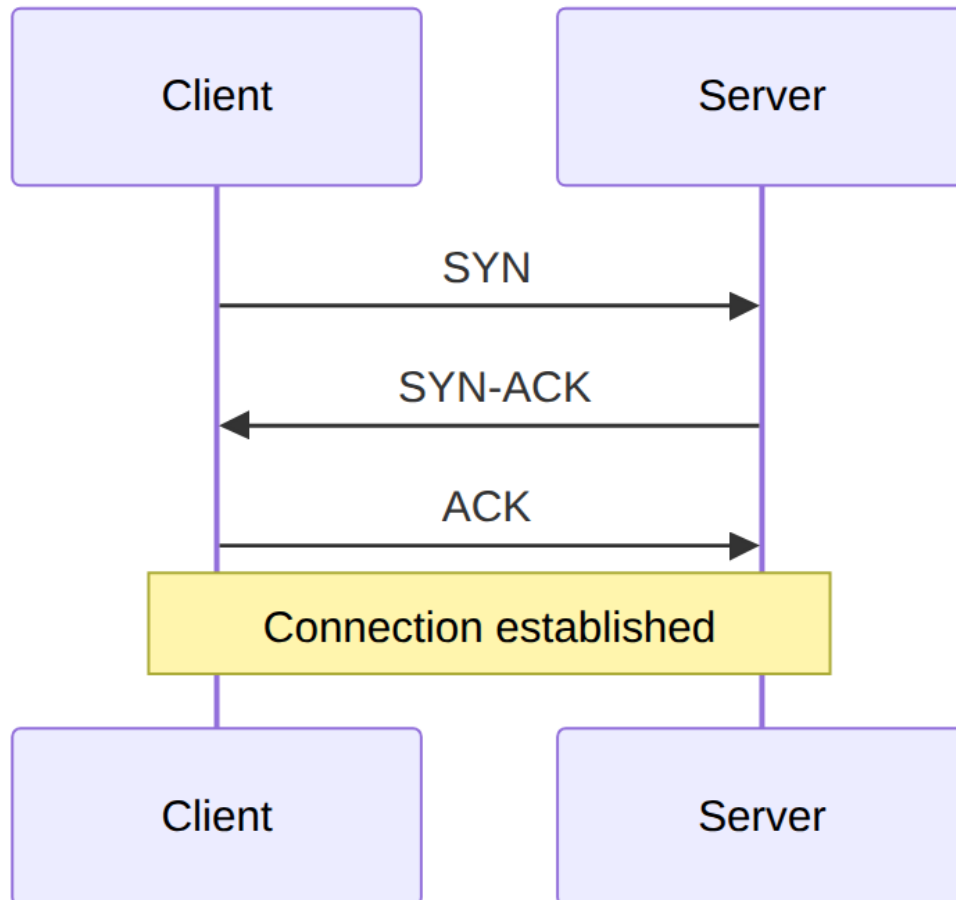


Figure 1: Architecture diagram

Key terms

Term	Meaning in this lecture
The first message is 1 or 2; 1	it is a warning, 2 means it is a fatal error.

Exam-oriented recap

- We shall now be looking at some of these security Applications.

- So, this SSL is one such protocol which provides you with an optional added layer of security with respect to whatever message you are sending and receiving over TCP/IP.
 - On top of it provides some additional functionality so that additional level of security is provided, ok.
 - So, SSL can be used, which runs on top of TCP/IP to develop any security application in general.
 - And there is another very important component or typically generated this, called LDAP – Lightweight Directory Access Protocol.
 - They must authenticate each other.
 - They take care of data security and data integrity that is the responsibility of the SSL record protocol.
 - So, whenever initially a connection is being set up here, the connection is a little different as compared with a normal TCP connection.
-

L35: Applications — Part II

Transcript: [35-applications-part-ii.md](#)

Video: <https://www.youtube.com/watch?v=3wiomVEvvKM>

Week / theme: Week 7 — Hash, PKI, steganography, network attacks

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Now, we continue with our discussion on Applications of cryptographic primitives to design security protocols.
- This is the second part of the applications lecture.
- Here we shall be talking very briefly about three different security protocols which are quite commonly used in the Internet, Transport Layer Security or TLS, IP security IPsec and secure HTTP.
- So, talking about transport layer security, in the last lecture we talked about SSL.
- Well SSL, we say, we saw it was a security layer which was sitting on top of TCP and was providing services like encryption, authentication etc.

What this lecture teaches

Core concepts from the lecture

Now, we continue with our discussion on Applications of cryptographic primitives to design security protocols.

This is the second part of the applications lecture.

Here we shall be talking very briefly about three different security protocols which are quite commonly used in the Internet, Transport Layer Security or TLS, IP security IPsec and secure HTTP.

So, talking about transport layer security, in the last lecture we talked about SSL.

Well SSL, we say, we saw it was a security layer which was sitting on top of TCP and was providing services like encryption, authentication etc.

to the applications which are using that SSL layer.

Now, this TLS or Transport Layer Security can be considered as an extension of that SSL.

Now, the primary aim of the TLS protocol is to provide security and data integrity at the transport layer level between two web applications.

Continued

Now, SSL is a service which can be used by any applications where TLS is specifically for the transport layer level for end to end communication between two hosts based on the transport layer.

TLS can be used to provide security and data integrity, ok.

Now, most of the web servers and browsers they support this TLS today so that all communication between them can be made secure, ok.

So, I am not going into give any detail of the protocol.

Secure shell is one protocol which is quite important, SSH.

Now, you see we are very familiar with a scenario where we are sitting on a computer.

We are doing a remote login to another machine and working on that.

There are very common kind of programs or applications which we use to do that.

Continued

One of the oldest and still very widely used commands is the telnet program or telnet command.

Using telnet we can do a remote login.

There are programs like rlogin, rcp, remote copy, you can copy a file from a remote machine to the local machine and so on.

Now, this protocol we are talking about here, this was originally developed in 1995, SSH, ok.

Now, this allows port forwarding which is some kind of a tunneling over SSH.

Tunneling, you recall is a mechanism through which some protocol data which is not supported at the current level or the layer which you are working on.

The entire packet including the headers will be treated as data.

It will be encapsulated with the header of the present layer protocol whatever it is and it will be tunneled or sent to the other sight.

Continued

On the other side the header will be taken out and the original data with the headers etc.

will be extracted, ok.

So, this supports tunneling over SSH and here the other advantage that proxies and firewalls can be very easily configured using this protocol.

So, most of the proxy servers and firewalls that we use to access them, we use SSH.

This pretty widely used.

Now, SSH version 1 for example, in this protocol there is a client server scenario.

There is a server which is providing some kind of secure access and the clients are accessing them using the SSH protocol.

There is also an SSH kind of a command on the Unix terminal if you use, ok.

Continued

Now, this server here has two different keys.

Now, there is a distinction which is made here.

One is something called a long term key; long term key is used for server identification, for the initial, identification and authentication.

So, this long term key is used to establish the initial connection.

So, you can say it binds the connection to the server and for this long term key we use 1024 bit RSA.

Of course, there are later versions now which use keys with higher number of bits like 2048 and so on, but in addition to this you say 1024 or 2048 keys are good no doubt, but as I said RSA is slow.

So, every time encrypting and decrypting with a longer key will take more time.

So, there is also another key which is called as short term encryption key which is modified frequently for example, every hour or so, ok.

Continued

Now, this key is relatively shorter in size typically 768 bit RSA, ok.

So, this short term key is refreshed often and during that period when the short term key is active the data which are transmitted and flows through the connection will be encrypted using the short term key, right.

This is how this protocol works.

Now, there would be multiple authentication mechanisms which are supported here.

Now it is of course, up to the user.

It is not that all these methods will have to be used simultaneously.

In a particular application, these are just some options which are available.

First is that you can have normal passwords, but this passwords will flow encrypted through the network.

Continued

These are protected by SSH encryption.

Say unlike the older times, wherever we used to do a remote login, while a hacker which was snooping in the network can retrieve your password, because they were flowing in packets which are carrying the passwords as plain text.

So, it was very easy to read them out.

There is a second mechanism you can have RSA based authentication using your private key or there is something called a challenge response.

Challenge response means I encrypt something using my private key.

I send it to the server; server will decrypt using my public key and try to verify something like that.

And also the other way around, the client can decrypt a challenge from the server and will return the corresponding hash value back to the server; server will verify whether its correct or not.

So, there are some mechanisms.

Continued

So I am not going to the detail, ok.

And thirdly there are some add on mechanisms which you can add for additional security.

Like, you can have some biometric mechanism like fingerprint recognition and so on; you can have smart cards.

So, using smart card you can authenticate yourself and this kind of add on mechanisms are also supported by SSH.

Now, there is a security pro, layer protocol even at the IP layer.

Well, we talked about the protocols which work above TCP and so on, but at the level of IP, there is a protocol called IPSec.

This provides secure packet transfer at the IP layer level.

So, as I said here we are trying to build some security into the IP layer and using IPSec you can have host to host or if you want firewall to firewall encryption and authentication, because you can have two organizational networks.

Continued

Let us say, you have one here, one here and you are sitting here.

This is one host and you are trying to communicate it another host here.

But there can be one firewall sitting in the boundary here and another firewall sitting in the boundary here.

So, this authentication and this kind of protection security can be provided for the connection between these two firewalls.

If you want, file, file to file or it can be even from host to host or end to end.

Now, these security features, these are normally not used in IPv4.

It's optional, but if you are using IP version 6, then you must have this feature incorporated or in power bits because it will be used.

There are two parts in the IPSec protocols; one is IPSec to the basic part which is responsible for encryption and authentication.

Continued

Now, in methods for encryption and authentication we have already discussed all those protocols and algorithms and these mechanisms are incorporated in this protocol.

This is an high level application.

And there is another part which manages the key.

How the two parties share key, public key, symmetric key, everything.

So, that is managed by the other part.

And in terms of the protection of data there are again two different modes; one is called the tunnel mode; other is called the transport mode.

We shall, we very briefly talk about these and the services that it provides.

As I told you this authentication and integrity is one thing.

Continued

Confidentiality using encryption, it can maintain confidentiality out of data and replay protection.

Because I mentioned earlier, there is something called a replay attack which can be exploited by the intruder, if your system or network is not that well protected.

The intruder can hear or listen to a sequence of messages or packets that are flowing through the network when some legitimate user is accessing some service.

Later on the intruder can try to replay those same packets send the same packets and expect a similar kind of response from the server.

So, he or she can get entry into the system possibly, ok.

Now, let us briefly look into these services and the modes.

Talking about the tunnel mode, what is done here is that an entire IP packet, that means, you think about this.

You have an IP packet.

Continued

So, you have the IP header in one part here.

You have the IP header and this is the IP data, ok.

Now, this entire thing is considered as data and you add an IPSec header to it.

This is the concept of tunneling.

The entire IP packet you are not taking out the header, the entire IP packet is put inside a IPSec packet, high level packet and sent on the other side using all encryption whatever mechanism you are using.

Now, here I told you that there are multiple mechanisms now where this IPSec or this encryption or secured links can be maintained.

You can maintain it between a pair of firewalls; between the two end machines or hosts or you can maintain it between a host to the nearest firewall.

So, it depends again on the scenario, on the application, on the environment which one you want to use, fine.

Key terms

Term	Meaning in this lecture
So, there is also another key which	as short term encryption key which is modified frequently for example, every hour or so, ok.
Challenge response	I encrypt something using my private key.
The authentication	it will verify the origin of the data from where it is coming.

Exam-oriented recap

- Now, we continue with our discussion on Applications of cryptographic primitives to design security protocols.
- Here we shall be talking very briefly about three different security protocols which are quite commonly used in the Internet, Transport Layer Security or TLS, IP security IPsec and secure HTTP.

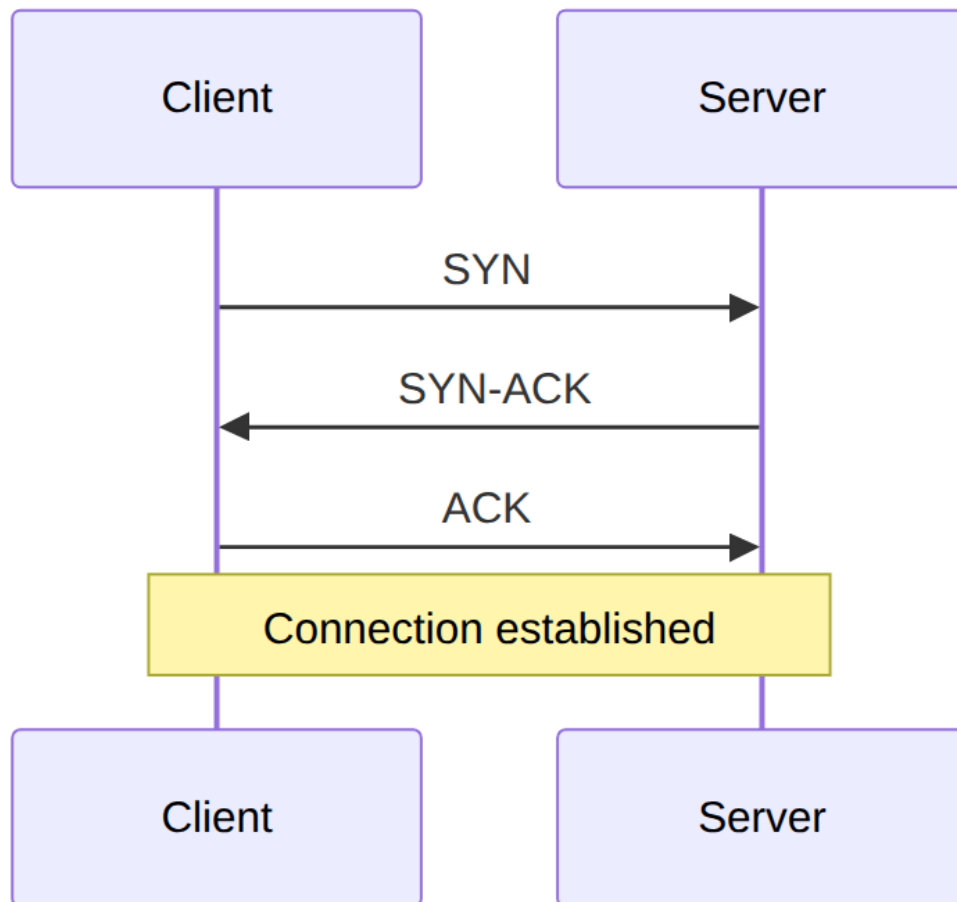


Figure 2: Architecture diagram

- So, talking about transport layer security, in the last lecture we talked about SSL.
 - Well SSL, we say, we saw it was a security layer which was sitting on top of TCP and was providing services like encryption, authentication etc.
 - Now, this TLS or Transport Layer Security can be considered as an extension of that SSL.
 - Now, the primary aim of the TLS protocol is to provide security and data integrity at the transport layer level between two web applications.
 - TLS can be used to provide security and data integrity, ok.
 - Secure shell is one protocol which is quite important, SSH.
-

L36: Steganography

Transcript: [36-steganography.md](#)

Video: <https://www.youtube.com/watch?v=VTs9gXi5Is8>

Week / theme: Week 7 — Hash, PKI, steganography, network attacks

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this lecture we shall be talking about something called Steganography, ok.
- Now, let us first try to understand what we are trying to discuss here.
- Now, in this lecture we shall first be talking about steganography and digital watermarking.
- We shall specifically be looking at some examples with image files and look at some examples.
- First let us look at what steganography means?.

What this lecture teaches

Core concepts from the lecture

In this lecture we shall be talking about something called Steganography, ok.

So, the title of the lecture is Steganography.

Now, let us first try to understand what we are trying to discuss here.

Now, we talked about networks; we talked about some security issues and security protocols that are typically used over a network to secure our data to achieve confidentiality, authenticity, integrity and various others.

Now, here we are talking about our own data, our own communication; we are trying to secure them, but to imagine we are now living in a world where so many different kinds of communication are going on over the network, over the public network.

Well, we are securing our own network, alright.

But, there are some other people which may not be that innocent, may not be that good who are also communicating among themselves with some malicious intent.

So, we should be on the alert; we should also be, try to find out whatever is going on; what the others are sending and receiving over the network.

Continued

This is just from the point of view of securing our, you can say infrastructure and in a much larger context securing our nation, ok.

So, if you can detect some communication that is going on, then you can take some action, alright.

But, steganography is a technique which is meant to hide some information so that you cannot detect them so easily.

Now, in this lecture we shall first be talking about steganography and digital watermarking.

There, these two are very similar things, but maybe they are, they used in slightly different context and steganography can be used in many different kinds of files.

We shall specifically be looking at some examples with image files and look at some examples.

First let us look at what steganography means?

First let us look at what steganography means?

Steganography as for the definition if you look at the dictionary meaning, it means covered writing.

It has come from a Greek word.

Covered writing means you have written something, but you are hiding it; no one else is able to see it.

This is the basic idea.

Hiding messages in innocent media.

Innocent media means generally you will not have any idea at all that there is some, there is a hidden message that is being carried.

But somehow that hidden message is hiding inside an apparently innocent media.

Continued

It can be a very nice picture; you are viewing a very nice picture, but inside that picture somewhere some information has been hidden, ok.

This is steganography, ok.

Steganography may or may not be used in conjunction with cryptography.

So, if the person who is hiding the message is doubly, you can say aware of the fact that he also wants to do some encryption before hiding so that if someone at all breaks it, if someone finds out that the steganography and extracts the information, but still, because this encryption that person will not be able to decode it.

So, you may possibly encrypt the message before hiding.

That is a more sophisticated way of data hiding.

Now, the thing is that in a normal channel if you send an encrypted message and if I capture it, that if I am not able to read it; that means, it must be encrypted.

So, the first thing is that there be some suspicion; that means, what are they sending among each other that they have to encrypt.

Continued

Are they good people or they are not so good people?

So, I do not know, ok.

So, any message flowing through in an encrypted form may raise suspicion, ok.

So, the other alternative to be, is to send in such a way that no one will suspect at all.

The message will be hidden.

There will be nothing visible which can attract any suspicion, ok.

Digital watermarking, as I said is something which is very similar to steganography; here also we are hiding something, but here there is a particular application.

Here let us say, we can have some copyright information like for example, some company produces some music, produces some music CDs, some movies on some media, CD, DVDs, Blu-rays and whatever various medias are there, online media.

Continued

Now, there can be some copyright or ownership information.

There can be licenses and other information that may be hidden into that media which the person who is downloading and listening will not be able to see.

But, if a person makes unauthorized copies, then the law enforcement agencies can check that and try to find out who was the original owner and whether it is a legitimate copy or not, ok.

This is different from steganography.

Only with the intent, normally we use the term steganography with the intent that something wrong is trying to happen.

Someone is trying to send something without the others knowing; that means, they do not want to share it with others, maybe some very secret information or very you can say not so good something malicious is going on, but in digital watermarking we

are trying to protect the copyright of some information which are generated by some authorized parties, but the technologies are same, similar, ok.

Let us look at the history of steganography and look at some of the very classical examples.

Well, the very first example of steganography was very interesting.

Continued

Some very secret information needed to be sent from one place to another, long distance.

So, what was done, a messenger who was carrying the message; so, he was not carrying the message on a piece of paper.

So, if the messenger gets captured, then the paper will also be seen.

The head of the messenger was shaved and some tattoo or some information with permanent ink was marked on the head.

Then some days were given so that the hair can again grow and then the messenger was sent.

So, apparently even if the messenger is caught, no one will suspect that he is carrying some secret information on his head.

So, when he reaches the intended destination, his head will be shaved again and the hidden message can be read out.

So, this was actually used in ancient times, ok and during World War II, some very simple type of this kind of steganography was used for some German spy to send a message from one post to another.

Continued

So, the idea was very simple.

He was carrying a printed message on a piece of paper, but the content of the message was apparently very, you can say straightforward, nothing suspicious.

Let us say “apparently neutral’s protest is thoroughly discounted and ignored”.

Blockade well, you cannot make anything out of it, but the sender and receiver knows how the information was hidden.

If we extract the second letter of each word like I extract this p e r s h i n g and so on then you extract something like this.

Pershing is, maybe the name of a ship it sails from New York June 1.

So, this is an information which you are sending to someone else so that, that person may be able to attack or do something based on that, ok.

So, this was one of the very old form of steganography, ok.

Continued

We use some terminologies in connection with steganography.

We talk about a cover medium that where we are hiding; if it is a text that is our cover medium; if it is an image that is our cover medium; if it is an audio clip or a music file that is our cover medium.

So, where we are hiding, ok.

Then the embedded message and if you are using encryption in addition some kind of, then there has to be some key also.

Let us call it steganographic key or stego-key and all 3 combined together will generate this stego-medium.

Now, the objective is this.

Cover medium and stego-medium should look very similar.

A person who does not know that this is carrying some hidden message will not be able to distinguish just by looking at this stego-medium.

Continued

That person will feel that he is actually looking at the original file only.

Multimedia files are typically used to hide messages like images, sound, movies, binary files, text files, but the other ways also.

Like you see, you have seen the IP packets, network packets, there are some fields which are unused.

Those unused bits can also be used to carry some message or information.

So, there are many ways, there are many fields in data, in files which are not used; you can also use those fields to carry some data.

Like some executable files.

You compile a program in C or C plus plus or Fortran, whatever.

You generate machine code.

Continued

Now, in the machine code, in the header, there are lots of fields which are not used.

You can also use those fields to carry some hidden information.

Now, specifically as I said we shall be talking about steganography in image files.

Now, a few terminologies, the size of an image, we talk about an image in terms of picture elements or pixels.

How many dots are there?

We imagine that a picture is made out of dots; let us say, we say 1024 by 1024.

There are 1024 dots horizontally and 1024 dots vertically.

That will define the size of my image and each picture element or pixel will be having a color.

Continued

That is, have an image is formed and a color is typically specified by some combination of the fundamental colors red, green, blue.

You know these three are fundamental colors RGB, as combination of Red, Green and Blue.

Typically, each of this red, green and blue can be represented in 8-bits or a byte.

In 8 bits the value can between 0 and 255.

Now, in hexadecimal, it will be 0 to FF.

Let us say black; the color black where red, green, blue all these components will be 0.

So, it can be encoded as 00 00 00, red, green, blue; let us say white, white means red, green, blue all are at the maximum intensity.

So, to the FF FF FF that is white; if you talk about pure red, only the red component is FF.



Figure 3: Architecture diagram

Key terms

Term	Meaning in this lecture
Covered writing	you have written something, but you are hiding it; no one else is able to see it.
Innocent media	generally you will not have any idea at all that there is some, there is a hidden message that is being carried.
Lossless	you are compressing alright, but if required you can uncompress it and get back the original image.
Like earlier I told you LSB transformation or	LSB steganography, the data can be easily destroyed.
Any such picture	not ultimately a stream of 0s and 1s that was hidden inside this larger image.

Term	Meaning in this lecture
In the next lecture we shall be looking at some other	of security which is also used quite popularly nowadays.

Exam-oriented recap

- Now, we talked about networks; we talked about some security issues and security protocols that are typically used over a network to secure our data to achieve confidentiality, authenticity, integrity and various others.
- Now, the thing is that in a normal channel if you send an encrypted message and if I capture it, that if I am not able to read it; that means, it must be encrypted.
- So, this is an information which you are sending to someone else so that, that person may be able to attack or do something based on that, ok.
- These are not very important to remember.
- But, suppose you are a person who is on the lookout of whether such secret message is being transmitted by some parties which are suspect, whom you feel they may be exchanging some information which are detrimental to your security.
- In the next lecture we shall be looking at some other means of security which is also used quite popularly nowadays.

L37: Biometrics

Transcript: [37-biometrics.md](#)

Video: <https://www.youtube.com/watch?v=ecfE3ZhUnKw>

Week / theme: Week 7 — Hash, PKI, steganography, network attacks

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Now, in this lecture without going into the detail of the techniques and technologies, we shall provide you with an overview of what is biometrics?.
- Now, in biometrics one thing you just understand that as it is said that the person whom you are authenticating has to be present physically in the place where this authentication is carried out.
- Based on some measurable biological or behavioral characteristics; or a combination of both; there can be several biological or behavioral characteristics that you may need to look at.
- Let us look at some of these one by one; fingerprint recognition; you have seen fingerprint readers in many places; I am sure.

What this lecture teaches

Core concepts from the lecture

In our earlier lectures, we have seen the various security primitives out of which authentication was one of the most important requirements.

Now, once the message is being transferred or transmitted over the network, you need to authenticate the two parties.

But there are applications where some person has to be authenticated.

The person has to be present in that place and you have to verify whether that person is indeed the individual who he or she is claiming to be; this is what is referred to as Biometric Authentication and this is the topic of this lecture.

Now, in this lecture without going into the detail of the techniques and technologies, we shall provide you with an overview of what is biometrics?

What are the various biometric traits that are used in practice and some of the applications?

Now, in biometrics one thing you just understand that as it is said that the person whom you are authenticating has to be present physically in the place where this authentication is carried out.

So, what are you authenticating?

Continued

You should authenticate some direct physical or psychological properties of that person, how he looks, his or her fingerprint, how he walks and so on; these are a few things which are typically used.

Let us see the basic definition of biometrics.

Biometric is defined as some automated method for recognizing individuals; this is the basic idea.

But how we can do it?

Based on some measurable biological or behavioral characteristics; or a combination of both; there can be several biological or behavioral characteristics that you may need to look at.

Some of the typical features which people have explored include fingerprint which is very commonly used, you know.

Face recognition; face, hand geometry like hand.

Every hand is unique like, how much gap is there between two fingers, what is the geometry, what are the lengths?

Continued

There are many features there and also some marks or lines in the hands; these are called hand geometry; this is also a very unique way of identifying a person.

Iris scan, the center of your eye is called iris.

You can scan an iris, there are some systems where this iris is used as biometric or you can scan your entire retina.

The entire eye, the retina that is more accurate than iris.

And some of your behavioral features like your signature, how you sign; create a signature and when you are typing on the keyboard; what are your features, just two persons will have some difference in the way they type, ok, keystroke dynamics.

Gait means how you walk; two persons their walking style will be distinctly different.

And of course, DNA is one of the biological properties; DNA of a person is supposed to be unique, but of course, DNA checking cannot be done instantaneously; it takes much longer time and there are several others.

So, you may use any one of them and if you want more robust and more accurate system; you can use multiple of them together.

Continued

Let us look at some of these one by one; fingerprint recognition; you have seen fingerprint readers in many places; I am sure.

Fingerprint recognition is it, it essentially, it looks at the tiny lines and curves and edges and ridges that are present in the fingers; tips of the fingers.

And there are some terms which are used crossover, cores, bifurcation, ridge ending, island, delta, pore; you identify where exactly in your fingerprint image these are located; these are called minutiae.

So, these places where there is a sudden change, these are called minutiae points; you identify the minutiae points and you can detect these features in your fingerprint.

So instead of storing in the entire fingerprint image, you can identify these and you can compress it into a very small quantity and by comparison you can actually identify a person.

So, there will be some kind of a pattern matching, but the problem is, this method is not very robust; like in terms of fingerprinting, you have to have a very clear fingerprint to have good detection probability, ok.

Sometimes, you may see, you may have to put your fingers several times before you are getting authenticated.

And if there is some dirt on your finger or some ink or there is some dirt on the surface where you are putting your finger on, there can be some error in scanning; so sometimes it may not be usable.

Continued

So, this fingerprint recognition is certainly one of the very popularly used methods, but this is not really a failsafe method.

Well, you can use fingerprinting at some doors for to gain entry into a premise, but you cannot use fingerprint for your bank transaction because it is not considered to be 100 percent safe.

Well, I said hand geometry carries lot of information like what are the lengths of your fingers, what are the gaps between the fingers, shapes of the fingers and if you look at the side view, side view what is, what is the geometry?

So, there are lots of features in your hand which are unique and also some marks on your hand that also can be seen in general.

These are more accurate than fingerprints, but the problem is that to put your hand, you need a larger scanner.

A fingerprint scanner will be very small, let us say about a inch in size, but hand scanner needs to be very large.

When iris as I said; iris cognition is something which is used in several places.

The central part of your eye, this is called the iris and there are some cameras which is specifically designed to capture your iris recognition.

Continued

So, these cameras use infrared light; one of these is an infrared source and the other is a camera and after capturing the image, the image is typically converted into vectors.

And well, this also is moderately accurate; it is also not very foolproof.

There can be some errors in validation or authentication even using iris.

Facial recognition is considered to be better provided you get a good image of your face.

You can see, you can see the eye; you can see the nose; you can see the ears; you can see the chin; there are so many features in a face, ok.

If you take the image of a complete picture, then the location and the position of facial features can uniquely identify a person.

But of course, as you can understand, the image must be made available in some restricted environment like proper background, proper lighting and so on.

Like while you are providing a photograph in many places like a passport application for example, or visa application; you are often asked to provide your picture in a specific format; in a light background, clear, face should be visible and so on, ok.

Continued

But another thing is that the expression of the face; when you are actually taking the picture for detection, for identification that also makes an important.

I have a cartoon here; so you see the same person can make so many different faces; so this is also a challenge.

So, there can be variations; so your detection mechanism should be robust against at least some of the variation; these are extreme variations of course, this is just a cartoon.

Voice is another very important biometric trait which have been explored; suppose I speak on a microphone.

I will get identified.

Because the way I speak, there are some very specific features with respect to the pitch intensity and quality of my voice, also in duration, ok; so voice verification also is very important.

There are many applications where you can activate some devices using your voice and only you can activate; if we, if someone else talks and instructs that will not be recognized.

So, that device have, will have the intelligence to identify the features of your voice and identify yourself from your voice.

Continued

But again it is not a general vocabulary or speaking, but certain specific commands, stop, go, up, down something like that you are speaking and the system is identifying it uniquely.

Retina as I said, retina involves much larger region of your eye and that is much more, much more accurate as compared to iris.

And retina is supposed to be unique to each person and even unique to each eye; the two eyes, the retinas will be different.

This method is pretty accurate, but the problem is that when you want to take the image of a retina; you have to open your eyes; open and you have to stare at a camera for a longer time which may be a little annoying and stressful to the person who you are scanning for recognition.

So, taking the retina image is a little troublesome; this is the only downside of this method.

So, talking about the typical application; there are many commercial applications you can think of.

Well you log in to a server; there can be some biometric also like you think of a mobile phone that is like your personal server.

There are newer mobile phones, modern mobile phone where you can unlock the screen by using your fingerprint for example, or user, using your face.

Continued

There are such schemes available.

Then electronic payment, there are many electronic payment gateway where some kind of biometric authentication is required.

Access control to region, you want to enter a room, enter a laboratory, enter a building; you may have to show your face, give your fingerprint, something like that.

Record protection; suppose you have some records if some information, confidential information stored somewhere; when you want to update it, you have to verify that it is actually you; you can again put some kind of biometric authentication in place before you can carry out that identification, ok; here is some of the examples.

Talking about government application, there are many such applications you already know of.

Passport control, visa applications, there you use border control that is visa, access control to facilities; government building some very secure places and Adhaar UID which we are all familiar with now that is also an initiative by the government that again uses a set of biometrics to uniquely identify a person, ok; these are some of the attempts.

Of course, a very big application is in forensics.

Well, when some crime has happened; usually the forensic experts go to the site and try to look for fingerprints; so that is one way.

Continued

And also you can identify some missing persons using some kind of biometric; maybe the person has lost his or her senses, not able to remember; there is a loss of memory.

So, you can check some kind of biometric trace to identify that person; some cops you are not able to identify a dead body, you can use biometrics and of course, criminal investigation I have already told, there are many applications in fact.

Now, talking about practical systems as I said no single system is 100 percent fool-proof.

So, you normally should have a combination of two or three important biometric traits to uniquely identify a person right; this is called multimodal biometrics.

Let us say you can have a combination of voice and face; you can have a combination of fingerprint, hand geometry and face; face, ok; face and voice sentence is repeated anyway, so you can have any combination of these.

So, as I told you, practical system should have some kind of better detection probability; identification probability and single biometric take may not give you that, you should use multiple or more than one.

But again this can be one level of security; if you are talking about some very sensitive applications you may need to add some added level of security on top of this.

Now, broadly speaking there are two ways in which you can use biometric for identification.

Continued

One is; one is to one which is authentication like I am saying that I am Mister XYZ, the system should identify that I am XYZ.

So, the idea is that I am sitting here; this is where I am stand, standing and this is my claim; I am saying that I am Mister XYZ.

So, what was done earlier?

Earlier all the users in the system were enrolled, data acquisition was carried out.

Suppose it was fingerprint, so all the fingerprints were acquired, some features, the minutiae points and the features are extracted from the images and some basic template for each user was generated and these templates were stored in a database.

So, when I say, I am mister XYZ; then the template corresponding to mister XYZ would be extracted that would be a single template and I am standing here.

So, I will again present my fingerprint, my data will be acquired, feature will extracted, template will be generated and there will be a template matching carried out here.

So, template matching will be one to one; my template will be matched against that single template taken out from the database whether they are matching or not.

Continued

If they match, then the system will say that well actually I am XYZ; it otherwise will say that there is no match, you are not XYZ, ok; this is for authentication.

But suppose you think of a scenario that the biometric information of all the criminals in a state are stored in a database.

Now, you catch hold of a suspect; something has happened; you catch hold of somebody; you try to find out whether that person is one of those criminals whose database is there.

So, now you have to compare one person against maybe 1000 persons or more than that stored in the database.

This will be a more time consuming process.

So, this is the second approach.

This is the verification approach.

So, a person is available whom we want to verify against all store templates in the database.



Figure 4: Architecture diagram

Key terms

Term	Meaning in this lecture
Biometric	some automated method for recognizing individuals; this is the basic idea.
Iris scan, the center of your eye	iris.
Gait	how you walk; two persons their walking style will be distinctly different.
The central part of your eye, this	the iris and there are some cameras which is specifically designed to capture your iris recognition.

Exam-oriented recap

- In our earlier lectures, we have seen the various security primitives out of which authentication was one of the most important requirements.
- But of course, as you can understand, the image must be made available in some restricted environment like proper background, proper lighting and so on.
- But another thing is that the expression of the face; when you are actually taking the picture for detection, for identification that also makes an important.
- Voice is another very important biometric trait which have been explored; suppose I speak on a microphone.
- Because the way I speak, there are some very specific features with respect to the pitch intensity and quality of my voice, also in duration, ok; so voice verification also is very important.
- And also you can identify some missing persons using some kind of biometric; maybe the person has lost his or her senses, not able to remember; there is a loss of memory.
- So, you normally should have a combination of two or three important biometric traits to uniquely identify a person right; this is called multimodal biometrics.
- But again this can be one level of security; if you are talking about some very sensitive applications you may need to add some added level of security on top of this.

L38: Network Based Attacks — Part I

Transcript: [38-network-based-attacks-part-i.md](#)

Video: https://www.youtube.com/watch?v=9o_6HLKetwM

Week / theme: Week 7 — Hash, PKI, steganography, network attacks

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this lecture, we shall be talking about some of the actual attacks that can be mounted on a network infrastructure; Network Based Attacks, the first part of it.
- But trying to bring down a system and other is SYN flooding attack which we mentioned very briefly earlier when we are discussing about the TCP connection establishment protocol.
- And what is the objective, to prevent legitimate users from accessing that service.
- So, if you look at this picture, you see here I have some kind of a server, let us say.
- Now, let us look at the first kind of attack called Smurf denial-of-service attack.

What this lecture teaches

Core concepts from the lecture

In this lecture, we shall be talking about some of the actual attacks that can be mounted on a network infrastructure; Network Based Attacks, the first part of it.

Now, when we talk about penetration testing in a network; obviously, network attack is the most important thing that comes to your mind.

Well, you will see the tools, the demonstrations.

You must have already seen some of them, but here let me tell you some of the basic ideas and technologies that are exploited, that are used to mount this kind of attacks so that you will have an idea, how this attacks are carried out and how we can possibly stop these attacks, ok.

Now, in this lecture specifically I shall be talking about denial-of-service attacks and specifically three types of such attacks; one is called Smurf DoS attack, other is called a Ping of death, it is not exactly a denial-of-service.

But trying to bring down a system and other is SYN flooding attack which we mentioned very briefly earlier when we are discussing about the TCP connection establishment protocol.

denial-of-service attack, we briefly mentioned earlier.

Now, what it is exactly?

Continued

It is an explicit attempt by an attacker or a group of attackers.

It can be a single person; it can be a group of persons.

They are trying to attack some network infrastructure, some service.

And what is the objective, to prevent legitimate users from accessing that service.

So, if you look at this picture, you see here I have some kind of a server, let us say.

The server is providing some service; it can be web server, it can be mail server, it can be whatever.

It can be an application server and here, we have a user who is sending some request for some service.

Now, if there is a denial-of-service attack, DoS attack that is mounted here; what will happen is that legitimate user will not be have, having access to this service.

Continued

Now, this kind of attack can be made more dangerous and effective by having some kind of distributed denial-of-service which means not only one, but several computers can mount such an attack and can bring the server down.

And these kind of attacks have been reported over time.

They are pretty frequent in that sense and they have increased in frequency, severity and sophistication where the persons who are attacking now they have a set of tools at the disposal which are extremely sophisticated.

So, as a method of defence, if you are the owner of that kind of service, you have to protect yourself adequately so that this kind of attacks cannot be easily mounted.

Now, let us look at the first kind of attack called Smurf denial-of-service attack.

Now, let me tell you how this attack happens?

Now, you see this ICMP is one protocol I talk talked about Internet Control Message Protocol.

The ICMP is a protocol that is part of the TCP/IP protocol suit.

Continued

It normally sends some kind of error messages between machines.

If there is something wrong, it can send an error message to all the persons connected in a network so that others can also know.

While using ICMP you can also try and find out whether some host or some machine is currently available or up or not, you can send something called an ICMP Echo Request; the other person if it is available, it will send back an ICMP Echo Reply.

This is one of the features of ICMP.

Now, this kind of an attack exploits that this ICMP echo and reply packet response feature that is available in TCP/IP.

You see there is a command called ping which is available on machines.

Ping actually generates this ICMP echo request packets.

You normally give a command ping with an IP address.

Continued

So, what will happen?

Such an echo request packet will go to that IP address and a response will come back and what we will get?

Whether the response is coming back and how much time it is taking for it to come back.

Normally, these packets are sent repeatedly one after the other and it will getting continuously, some statistics that whether the network is up and how much time it is requiring to reach and the response come back, ok, fine.

Now, this ping request packet as I said is nothing but this ICMP echo request.

In this attack, what is done?

This ping request packet is sent to a broadcast address.

You look at IP address.

Continued

I tell you in the host part, if I put all one.

It refers to as a broadcast address.

Now, suppose I have a network and I want to attack one particular host.

Let us say this host is X and this is your attacker, let us see.

So, what the attacker can do?

Attacker can send a packet to this network with a broadcast address.

So, the destination address will be a broadcast address means which will be sent to everybody; all the computers in this network, this packet will be delivered.

But in the source address part the attacker has done some mischief.

Continued

He has done something called IP spoofing which means instead of the address of A, he has substituted this with the address of X.

Let us say there are 10000 computers here in this machine.

So, if such a broad cast packet comes, all this 10000 machines will be sending back the echo reply packets.

But they will not be sent to A, but they will all be sent to X.

So, X will be flooded with echo reply packets, ok.

So, there will be a large number of response packets which are ping reply or ICMP echo reply, which can overload the victim.

Now, how you can protect this kind of an attack?

Well, one simple way is to configure the edge router in every network to not allow packets to go out which have broadcast address as the destination.

Continued

To reject external packets with broadcast address as destination well, that is possibly an attempt to mount this kind of an attack, if you can stop such packets, then this kind of an attack will not be easy to mount, right.

So, this is pictorially what I have just now mentioned.

Let us say this is the host which an attacker tries to attack and the attacker is sitting here and this is a network.

Let us say there are three computers here, the small example.

So, what this attacker does?

It will send one ICMP echo request packet with this source address as spoofed, using IP spoofing.

So, it will change it to DoS target which is this DoS target and destination will be a broadcast address of this network.

So, it will be reaching all three computers and they will all be sending echo reply packets and they will all be targeted to DoS target.

Continued

It will be 3 ICMP echo response with the destination DoS target.

So, if there are n number of machines in this network, there will be n packets which will be targeted to this.

So, this is one simple way to overload a server with junk packets, large number of packets.

See the idea is that if a large number packet reaches the destination which we are trying to attack, then any legitimate user who is trying to send a packet to access a service will find that the link has become very slow.

Because the servers network means network buffer may become full with the incoming packets and the legitimate packet, legitimate packets which are coming, they will find that the buffers are already full and those request packets will be discarded.

So, this is like a denial-of-service.

So, this is another pictorial depiction, where here we have the attacker.

This is your victim system and this is a network which allows broadcast enabled packets to come.

Continued

Well, if you want to stop this, your network can reject any incoming packet with broadcast address as a destination.

Suppose it is not so.

It is broadcast enabled network.

So this fellow will be sending a packet here and broadcast enable packet will be generating a large number of packets mocked by these red arrows to this victim system.

Just what I said, this is the idea.

Now, this another kind of our attack, this I mentioned.

This exactly not a denial-of-service, but a way to bring a machine down; the idea is like this.

This is called ping of death.

Continued

Here also we use ICMP ping messages.

Now, a normal ping will generate two messages.

As this picture shows, if you give a ping from a source to destination, they will be an echo request followed by echo reply.

Now, this echo request and echo reply packets are typically small packets.

They do not contain too many bytes.

So, it is assumed that it will be certainly less than the maximum allowed size of 64 kilobytes, 65,536.

But in this attack, what is done?

A echo packet is deliberately sent which is larger than this maximum size.

Continued

So, what will happen?

Because it is larger there will be a fragmentation, multiple IP fragments will be created and they will be sent.

So, they will be smaller segments, the fragments, but at the others side when it there reassembled, it will be discover, discovered that the total packet size will be greater than 64 kilobytes and it cannot be delivered to the ICMP destination, because it can only receive packets up to a maximum of 64 K.

So, there are systems where if such a large packet comes, which is too large to handle, then this, then the software at the receiving end may either crash or the system may reboot.

But of course, not all systems are like this.

If the systems are not well configured, they might get crashed or reboot, if a two large packet comes and tries to reach an application at the destination.

This is the basic idea here.

Mounting the attack as I said, so what is the idea?

Key terms

Term	Meaning in this lecture
So, the destination address will be a broadcast address	which will be sent to everybody; all the computers in this network, this packet will be delivered.
He has done something called IP spoofing which	instead of the address of A, he has substituted this with the address of X.
Because the servers network	network buffer may become full with the incoming packets and the legitimate packet, legitimate packets which are coming, they will find that the buffers are already full and those request packets will be discarded.
This	ping of death.
That	a Bot.
Spoofed SYN packet	the destination address, they are modified.
Cookie	some information that is temporarily maintained in the server, which is relevant to some connections.

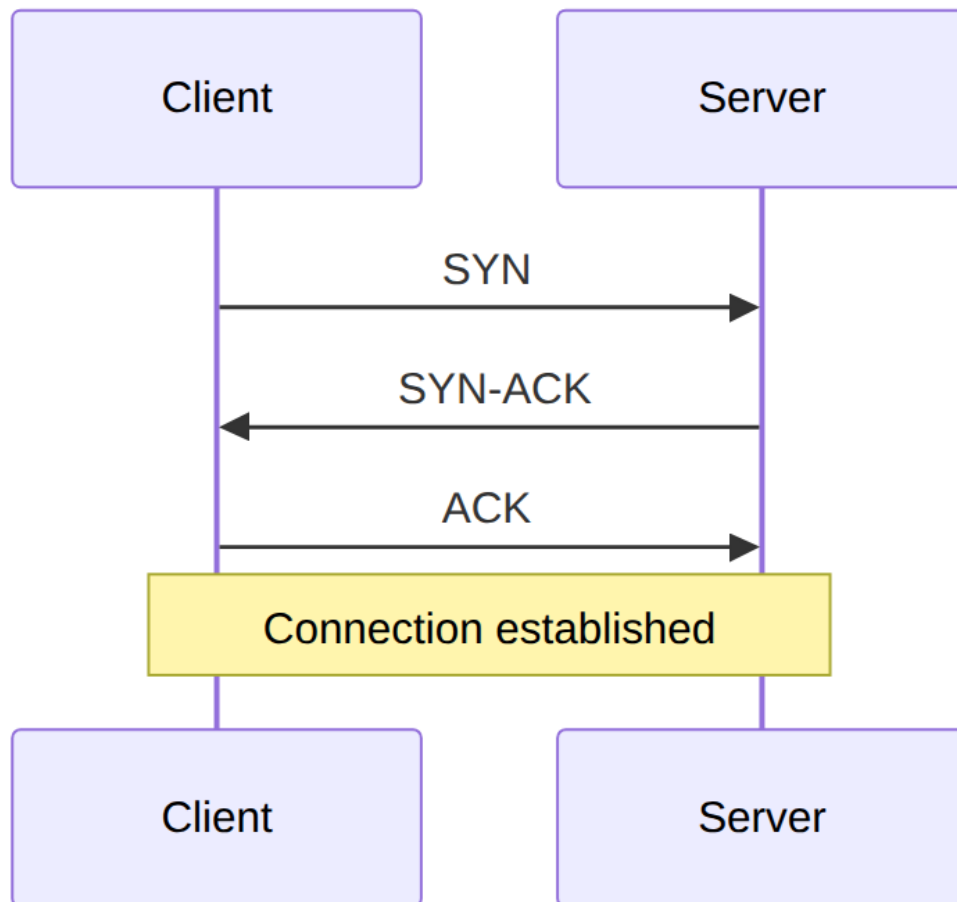


Figure 5: Architecture diagram

Exam-oriented recap

- In this lecture, we shall be talking about some of the actual attacks that can be mounted on a network infrastructure; Network Based Attacks, the first part of it.
 - Now, when we talk about penetration testing in a network; obviously, network attack is the most important thing that comes to your mind.
 - Now, in this lecture specifically I shall be talking about denial-of-service attacks and specifically three types of such attacks; one is called Smurf DoS attack, other is called a Ping of death, it is not exactly a denial-of-service.
 - But trying to bring down a system and other is SYN flooding attack which we mentioned very briefly earlier when we are discussing about the TCP connection establishment protocol.
 - denial-of-service attack, we briefly mentioned earlier.
 - It is an explicit attempt by an attacker or a group of attackers.
 - They are trying to attack some network infrastructure, some service.
 - Now, if there is a denial-of-service attack, DoS attack that is mounted here; what will happen is that legitimate user will not be have, having access to this service.
-

L39: Network Based Attacks — Part II

Transcript: [39-network-based-attacks-part-ii.md](#)

Video: https://www.youtube.com/watch?v=8v3HF_xNbRI

Week / theme: Week 7 — Hash, PKI, steganography, network attacks

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this lecture, we continue with our discussion on Network Based Attacks.
- So, we continue with our discussion.
- So, in this lecture, we shall mainly be covering an enhanced version of denial-of-service called distributed denial-of-service attack in short DDoS.
- If you look at the diagram here, you see the victim is out here.
- So, let us look at the basic idea using another diagram.

What this lecture teaches

Core concepts from the lecture

In this lecture, we continue with our discussion on Network Based Attacks.

If you recall in our previous lecture, we had talked about some kinds of network based attacks, in particular the denial-of-service attack and some of the mechanisms using which such an attack can be mounted.

So, we continue with our discussion.

So, in this lecture, we shall mainly be covering an enhanced version of denial-of-service called distributed denial-of-service attack in short DDoS.

We shall see how such attacks work specifically, some HTTP based flooding attack, called HTTP flood attack, and finally, we shall be talking about some of the general safeguards on or defence against such attacks.

So, let us start by talking about distributed denial-of-service attack.

Well, in a traditional denial-of-service attack, you can recall, there is an attacker who is trying to flood a victim machine by usually a large number of junk packets.

Distributed means something similar happens, but the attack is mounted not from a single machine, but from many machines.

Continued

So, you will see here, the idea is, there are multiple compromised systems that are used to mount an attack.

If you look at the diagram here, you see the victim is out here.

This is the victim computer or computers which are attacked, obviously over the internet, and there are multiple computers which are all compromised and are under control of the so called attacker.

The attacker will be controlling these machines and all these machines, they can be thousands in number.

They will be mounting a distributed or parallel attack on the victim; they will all be sending large number of packets so that normal service gets affected.

Now, the issue here is that this kind of a distributed denial-of-service attack as I said, is launched from multiple sources, not one, but several computers can mount this kind of an attack in parallel.

And because it is mounted from multiple sources, it becomes that much more difficult for the system, system administrator to detect that this kind of an attack is happening, ok.

And generally detection and preventing this kind of an attack becomes more difficult, fine.

Continued

So, let us look at the basic idea using another diagram.

Here let us assume that the attacker is here, this is the attacker machine.

We sitting on some machine and somehow the attacker has compromised a number of computer systems on the internet.

These are the so called slave machines.

And attacker is directing the slave machines to mount some kind of a distributed attack on the victim so that each of them will be sending a large number of some kind of packets to the victim.

And the victim will be flooded with all those request and finally, a denial-of-service scenario will take place.

Now, the issue here is that the reason that this kind of attack is much more difficult to detect and pinpoint, you see the attacker might have compromise the slaves, and the slaves are made to mount the attack.

But at the point at the time, when the slaves are mounting the attack maybe the attacker is no longer in the network, the attacker may be detaching or removing itself from the network.

Continued

So, it becomes almost impossible for anyone to look at the attacker when an attack is being taking place, because the attacker is not actually mounting the attack, there are number of slave machines which are mounting the attack on behalf of the attacker, right.

So, this is a slightly more detailed picture.

And here we talk about some of the terminology or terms that are frequently used in this context.

Well, here on top you see the attacker that is a machine where the hacker is sitting and actually is coordinating the attack.

There are some computer systems which are called handlers.

Well, handlers again are machines which are under control of the attacker and these handlers they have so called botnets, a large number of botnets under each of them.

It is, this handler will be having several botnets, this handler will be having several botnets and so on.

And all these botnets together will be mounting the attack on the victim machine, ok.

Continued

Now, let us understand these terminologies.

Well, attacker is a machine as I told you.

Handlers are also computer systems which the attacker will first compromise, all maybe this handlers are machines of some of the attacker's friends.

They have, they have allowed the attacker to use or access those machines.

Now, there are some terminology bot.

What is meant by bot?

Bot is nothing but a small segment of code, a program code which typically runs in a repetitive fashion that is the definition of a bot.

Usually, a bot carries out some repetitive tasks like sending a packet to a victim host, a large number of such packets.

Continued

In an alternative loop, some repetitive task is carried out.

Typically the operation of a bot is relatively simple in nature.

And this botnets that I have shown in the diagram, what is a botnet?

Botnet is a number of system, computer systems or any device.

It can be your mobile device also, any internet or network connected system you can say and each of these machines are running one or more bots.

Somehow this handler has inserted or installed some bots on those machines.

Depending on some weak points, the machines are hacked into and bots are installed and these bots are running on those machines.

So, the machines on which the bots are running, these are called botnets.

Continued

Now, this large number of botnets, botnets can be thousands and even more in number.

These botnets are actually used to perform this distributed denial-of-service attack, the DDoS attack.

Large number of botnets are firing packets to the victim, ok.

And on behalf of the attacker, all these botnets are working.

They are usually mounting an denial-of-service attack or sometimes can also gather some information from the victim machine depending on the scenario, ok.

This is how roughly things work.

Now, let us look at a single bot or a botnet.

How the bot typically attacks a victim's machine out here.

Continued

You see what a bot typically does is something like this.

Let us say bot will not directly send a packet, because it can, but if a bot directly sends a packet then it will be easy to detect.

The victim machine, system administrator can detect the packets are coming from that particular IP address and so that particular IP address must be a malicious entity.

But in the contrast, what the bot might do in an intelligent way, a bot is sending some packet to some server, server on the network, but before sending what it does, you know that IP spoofing can be done, it is not a very difficult thing.

That in the source address instead of specifying the address of itself, it will specify the address of the victim machine which it is trying to attack.

And bot is telling or asking the server to send a lot of data, let us say it is asking it to download a very huge file, let us say a file of 1 gigabyte size.

Server who received this request, and it will try to fulfil it, but the destination address is not the address of the bot, but the address of the victim, so that data it will be sending directed to the victim machine.

So, there will be many such bot doing something similar and if you try to tress back the attack you will land up into the server, you will not know exactly who was the origin or who was the originator of the attack.

Continued

This is how in a distributed fashion this kind of attacks can be mounted.

And the situation can become worse if you have a cloud kind of a scenario; you know in a cloud there are very large number of servers available.

So, instead of one server, if the attacker using some kind of command and control mechanism can send that kind of a request to the cloud providers, then all these servers will start sending huge volumes of data to the victim network or the victim machine.

So, this will become a much serious kind of attack, because this cloud servers are much more powerful; they can send packets much faster and the victim machine will be overwhelmed with packets or requests in a much more effective and faster way, fine.

Now, as I said this kind of distributed denial-of-service attack is difficult in terms of locating the source who was the originator of the attack, where the attacker is located.

Because the attacker is mounted by other machines, the attacker is mounted by other machines, the original attacker may not be in the picture at all when the attack is being mounted, ok.

So, there are some approaches which may be followed to try and locate the attacker.

Let me see what actually happens.

Continued

It is really hard to find the attacker is the reason, is the originator of the attack.

Firstly, they have used some of the handlers.

Those are intermediate machines, and handlers in turn they are using so called botnets, ok.

So, this is some kind of a distributed kind of a scenario coming in where the attacker is not in the picture.

So, the, and I said the originator may not be active at all when the attack is actually mounted, ok.

So, these are some reasons why this attack is typically very difficult to locate and prevent.

Now, what we can do, we can try to find that which are the agents or the handlers which are mounting the attacks and which are the botnets.

But again, this is not easy because as the example I showed just a couple of slides back that the source IP address may not be the original IP address of the botnet.

Continued

The IP address may be changed to the IP address of the victim.

So, this server, if you look at the server log what are the packets that came to the server, you cannot locate the botnet machines because the source address was modified, ok.

So, in order to find out you may need to examine traffic at many points in the routers, different ports of the routers, on which port more number of packets are coming.

So, you will be using that link as a suspect, go to the next level router, again find out in that router from which point more number of packets are coming, in that way, you may try to systematically try and locate where the botnets are, ok, but it is not easy, it is rather difficult.

And it requires some kind of collaboration between a number of organization, because all these routers may not be belonging to you, right.

So, there is another kind of an attack which is based on HTTP request and response.

This is called HTTP flood attack.

This is also some kind of a denial-of-service attack, distributed denial-of-service.

Continued

So, as it said, this is also a type of DDoS attack, but here the idea is we are flooding the target server with HTTP requests.

We are asking for some websites or we are submitting some forms to a web server something like that.

Typical HTTP requests that are formed; we are using something like this.

Now, the concept is similar by sending a large number of HTTP requests like in this picture you see, these bots are all sending HTTP requests to a server.

And the server is becoming flooded with these requests.

And if there is a legitimate client on the other side who is actually trying to use the server, the client will find that the server is not accessible.

It is become very slow, because of this large number of HTTP requests that these bots are sending to the server, ok.

So, it is mentioned here once the target has been saturated with this kind of HTTP requests, denial-of-service will occur; legitimate requests cannot be serviced, fine.

Key terms

Term	Meaning in this lecture
Distributed	something similar happens, but the attack is mounted not from a single machine, but from many machines.
This	HTTP flood attack.
That	an captcha.

Exam-oriented recap

- In this lecture, we continue with our discussion on Network Based Attacks.
- If you recall in our previous lecture, we had talked about some kinds of network based attacks, in particular the denial-of-service attack and some of the mechanisms using which such an attack can be mounted.
- So, in this lecture, we shall mainly be covering an enhanced version of denial-of-service called distributed denial-of-service attack in short DDoS.
- We shall see how such attacks work specifically, some HTTP based flooding attack, called HTTP flood attack, and finally, we shall be talking about some of the general safeguards on or defence against such attacks fine.
- So, let us start by talking about distributed denial-of-service attack.
- Well, in a traditional denial-of-service attack, you can recall, there is an attacker who is trying to flood a victim machine by usually a large number of junk packets.
- Distributed means something similar happens, but the attack is mounted not from a single machine, but from many machines.
- So, you will see here, the idea is, there are multiple compromised systems that are used to mount an attack.

L40: DNS and Email Security

Transcript: [40-dns-and-email-security.md](#)

Video: <https://www.youtube.com/watch?v=MMNYbHvO4CM>

Week / theme: Week 7 — Hash, PKI, steganography, network attacks

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this lecture we shall be talking about some of the security issues in name server and email servers.
- These are the basic concepts that will be covered in this lecture DNS, some kind of attacks which uses DNS, like, DNS poisoning attacks and how we can secure electronic mail exchanges, ok.
- So, we shall be talking about security issues in domain name system (DNS) server and also in email systems.
- These are the basic concepts that will be covered in this lecture DNS, some kind of attacks which uses DNS, like, DNS poisoning attacks and how we can secure electronic mail exchanges, ok.
- Talking about domain name system or DNS, we all are familiar with what DNS is?.

What this lecture teaches

Core concepts from the lecture

In this lecture we shall be talking about some of the security issues in name server and email servers.

The title is DNS and Email Security.

So, we shall be talking about security issues in domain name system (DNS) server and also in email systems.

These are the basic concepts that will be covered in this lecture DNS, some kind of attacks which uses DNS, like, DNS poisoning attacks and how we can secure electronic mail exchanges, ok.

Talking about domain name system or DNS, we all are familiar with what DNS is?

On the Internet whenever you want to access some resource, we have a name or a URL.

Using the URL like for example, www google dot com that is the example of a URL, but before we can send some requests to google dot com we have to find out the IP address of the corresponding machine.

Only then a packet can be sent.

Continued

So, DNS server helps us in retrieving the IP address from a given name or domain name, ok.

So, it maintains essentially the correspondence between host name and IP address.

Each host is given a name.

I have given example google dot com.

For example, at IIIT Kharagpur, our server name is iitkgp dot ac dot in.

That is the name of our server, web server, ok.

And this information host IP address, host name and IP address correspondence, this is stored in a database.

What kind of a database?

Continued

You see, DNS is a server program, domain name system that DNS maintains a local database with it and in that database among other things this host name and IP address correspondence, this information is stored, ok.

And this database is not a single database, because all information cannot be made available in one place.

For example, in your DNS server which you have installed, you cannot have the information about all the domain names in the entire world.

There are millions of such names, right.

So, you cannot have everything here.

So, there should be some kind of a hierarchy.

You first try to answer, if you do not have the information ask someone else.

That someone else says if does not know, he will ask someone else again.

Continued

Like that there will be some kind of a hierarchy, ok.

So, in a hierarchical fashion the database is maintained, because as I said, if you had a single centralized database where everything is stored in one place, firstly, it is very difficult to maintain and secondly, if that central database fails then everything fails.

You cannot use anything, ok.

Now, DNS server provides typical services like these.

Like, the most important I told you, is the host name to IP address translation.

Given the host name, it will give you the IP address and it supports something called host aliasing.

Like, a single host may be having various names.

You can have multiple names for a single computer.

Continued

If you want, if you pay for the domain names, you can have multiple names registered.

Also it supports load distribution.

Load distribution means, I give an example of google dot com, but google dot com does not refer to a single machine, there are large number of machines which are maintained by Google.

They are all having the same name google dot com.

There are a set of IP addresses for a single canonical name like google dot com.

These servers too have some kind of load balancing.

Suppose, I am sending a request to google dot com, I will be contacting my nearest server.

If there was a single server, everyone was accessing that.

Continued

That server would have been really overloaded, right, ok.

Now, distributed DNS server, as I told you DNS is not in one place, it is some kind of a hierarchical structure.

Let us give an example.

Suppose, we want to access gmail dot com.

When I say gmail dot com, from the right side com then gmail in that order these are the names of some DNS server; com refers to a DNS server in the dot com domain, gmail refers to one DNS server under that com that refers to the gmail dot com.

It starts with a route.

Initially, there is a, we refer to as a root DNS server.

So, everything is under root.

Continued

Under root the first thing here this com, there can be com, there can be org, there can be edu, there can be so many other things.

Like in India, we know dot in, country domain names, large number of such.

I have just only showed 3.

Under com all websites which end with dot com they will have their own DNS servers.

They will all be located.

For example, there will be some DNS server for gmail dot com, DNS server for amazon dot com and so on.

For org, I have given one example pbs dot org; edu stanford dot edu; University of Massachusetts umass dot edu and so on.

So, this kind of domain name server, DNS server is not one.

Continued

There can be multiple and I have just showed 3 levels.

There can be large number of levels in this hierarchy, ok.

Under the Stanford there can be several departments, each of them may be having their DNS servers and so on, ok.

Now, when a client sends a request to a DNS server, let us say, it requires that I have this name gmail dot com give me the IP address.

Now, there are two alternatives.

First is called iterative.

Iterative means suppose this is my client machine, ok.

Client is sending a request to the nearest name server.

Continued

Nearest name server replies back to the client saying that well, I do not have the information, but please connect the next level root server, next level DNS server.

So, it sends the request to next level.

Again a request may come back saying that well I do not have the information, please send the request to this DNS server and finally, this DNS, this DNS server might have the information in the database.

It sends back the correct response.

This is called iterative.

The client sends multiple requests to multiple DNS servers one by one, depending on the response it has received from the previous one.

So, the client has to handle a large number of requests and responses, right.

This is called iterative name resolution.

Continued

But recursive name resolution is slightly different.

Here the load on the client is less.

So, what happened is something like this.

Suppose again this is the client.

The client is sending a request to the nearest name server.

Name server may not be having the information, but instead of sending the request directly back to the client, it sends the request to the next high level name server and next high level server sends the request to the next high level server.

So, the client is not disturbed.

And once the result is found then the response follows the same path and finally, it will come back to the client.

Continued

So, to the client as if the client had sent one request and received one response.

But internally the name servers were working among themselves recursively to resolve the domain name.

So, this is what is mentioned here, ok, fine.

DNS caching is one important.

You see when you request for a, for something to a DNS server, DNS server may not be having it in its table, so it asks some other DNS server and gets back the result for you.

But, what it does in addition?

It enters that information in this local table or a local temporary memory called cache, DNS cache, because it expects that you may send that request again in the near future and if you send, it can send back the response directly from the cache.

It will not again send it to the next high level root server.

Continued

That is the purpose of the cache.

So, DNS caching is something which is very common.

It is used to increase the efficiency of operation, ok.

So, it is mentioned here once a DNS server learns about a name IP address pair, it puts it into a cache, a fast memory, a portion of the memory.

And these are not permanent entries.

They have some timeout, maybe a few hours, few days, 1 week.

After that they will automatically be removed from the cache from the memory, right.

So, the requests that got resolved in the higher level DNS server usually those information at cached in lower level servers, so that when future requests come, they can be resolved at that level itself, ok.

Key terms

Term	Meaning in this lecture
First	iterative.
Iterative	suppose this is my client machine, ok.

Term	Meaning in this lecture
This	iterative.
This	iterative name resolution.
That	integrity, data integrity and authenticity of denial of existence.
This	base 64 encoding.
It encrypts the hash value using KR,	private key of sender A.
Then finally, I compress, Z	compress, zip and that compressed version is sent over mail to the receiver.

Exam-oriented recap

- In this lecture we shall be talking about some of the security issues in name server and email servers.
- The title is DNS and Email Security.
- So, we shall be talking about security issues in domain name system (DNS) server and also in email systems.
- These are the basic concepts that will be covered in this lecture DNS, some kind of attacks which uses DNS, like, DNS poisoning attacks and how we can secure electronic mail exchanges, ok.
- On the Internet whenever you want to access some resource, we have a name or a URL.
- Like, the most important I told you, is the host name to IP address translation.
- So, this will avoid frequent visit to the higher level DNS servers, this is the advantage.
- But with this advantage comes some other problems also, which we shall see.

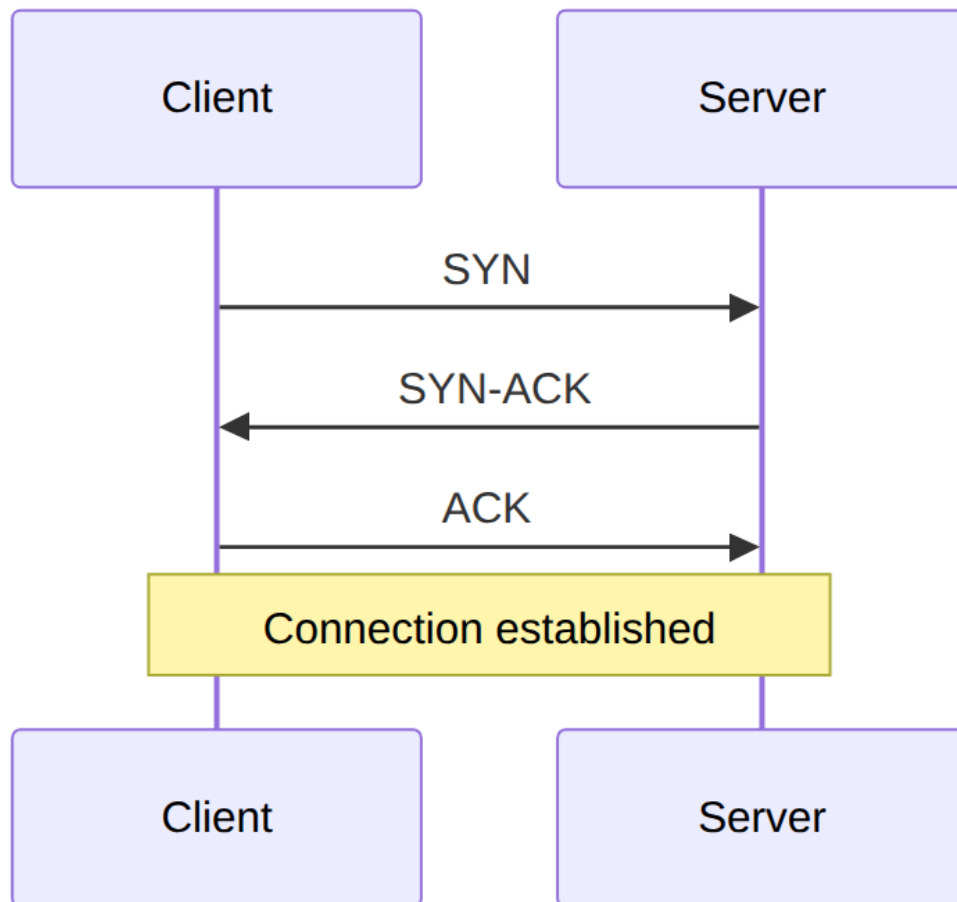


Figure 6: Architecture diagram